

“Malicious Insider Detection System in an Organisation”

A

Project Report

*submitted in partial fulfilment of the
requirements for the award of the degree of*

BACHELOR OF TECHNOLOGY

in

COMPUTER SCIENCE & ENGINEERING-AIML

By:

Name	USN NO	Program
D.LAKSMI SAILAJA	23BTRCL038	CSE(AIML)
V.DHARNISH	23BTRCL040	CSE(AIML)
C.V.PRANAVI	23BTRCL175	CSE(AIML)
A.HARSHAVARDHAN	23BTRCL247	CSE(AIML)

Under the guidance of

Mentor Name: Dr.SANKAR.K

Position/Post: Associate Professor

Program Name: AIML



**Faculty of Engineering and Technology
Jain (Deemed to be University) Bengaluru
562112**

Department of Computer Science and Engineering
School of Computer Science & Engineering
Faculty of Engineering & Technology
Jain Global Campus, Kanakapura Taluk - 562112
Ramanagara District, Karnataka, India

CERTIFICATE

This is to certify that the project work titled “**Malicious Insider Detection System in an Organisation**” is carried out by **A.JAVEED BASHA(23BTRCL167),CRVAMSI(23BTRCL172),D.VAMSI(23BTRCL179),G.KEERTHANA (23BTRCL186),I L SASIDHAR REDDY (23BTRCL193)** bonafide student(s) of Bachelor of Technology at the School of Engineering & Technology, Faculty of Engineering & Technology, JAIN (Deemed-to-be University), Bangalore in partial fulfillment for the award of degree in Bachelor of Technology in Computer Science and Engineering, during the year **2023-2024**.

Dr. V Chandrashekar

Head of department,
Computer Science and Engineering,
School of Computer Science & Engineering, Faculty of Engineering & Technology
JAIN (Deemed to-be University)

Dr. Sankar k

PCL coordinator & Mentor,
Computer Science and Engineering,
School of Computer Science & Engineering, Faculty of Engineering & Technology
JAIN (Deemed to-be University)

DECLARATION

We, **A.JAVEEDBASHA(23BTRCL167), CRVAMSI(23BTRCL172), D.VAMSI(23BTRCL179), G.KEERTHANA (23BTRCL186), I L SASIDHAR REDDY (23BTRCL193)** students of IV Semester B.Tech in **Computer Science and Engineering (Artificial Intelligence and Machine Learning)**, at School of Engineering & Technology, Faculty of Engineering & Technology, **JAIN(Deemed to-be University)**, hereby declare that the internship work titled “ **Malicious Insider Detection System in an Organisation**” has been carried out by us and submitted in partial fulfillment for the award of degree in **Bachelor of Technology in Computer Science and Engineering** during the academic year **2023-2027**. Further, the matter presented in the work has not been submitted previously by anybody for the award of any degree or any diploma to any other University, to the best of our knowledge and faith.

Name	USN NO	SIGNATURE
A JAVEED BASHA	23BTRCL167	
CR VAMSI PRASAD	23BTRCL172	
DASARI VAMSI	23BTRCL179	
G KEERTHANA	23BTRCL186	
I L SASIDHAR REDDY	23BTRCL193	

ACKNOWLEDGEMENT

It is a great pleasure for me to acknowledge the assistance and support of a large number of individuals who have been responsible for the successful completion of this project work.

First, I take this opportunity to express my sincere gratitude to the Faculty of Engineering & Technology, JAIN (Deemed to-be University) for providing me with a great opportunity to pursue my Bachelor's Degree in this institution.

I am deeply thankful to several individuals whose invaluable contributions have made this project a reality. I wish to extend my heartfelt gratitude to **Dr. Chandraj Roy Chand, Chancellor**, for his tireless commitment to fostering excellence in teaching and research at Jain (Deemed-to-be-University). I am also profoundly grateful to the honorable **Vice Chancellor, Dr. Raj Singh, and Dr. Dinesh Nilkant, Pro Vice Chancellor**, for their unwavering support. Furthermore, I would like to express my sincere thanks to **Dr. Jitendra Kumar Mishra, Registrar**, whose guidance has imparted invaluable qualities and skills that will serve us well in our future endeavors.

It is a matter of immense pleasure to express my sincere thanks to **Dr. V Chandrashekhar, Program Head of Computer Science and Engineering (Artificial Intelligence and Machine Learning)**, School of Computer Science & Engineering Faculty of Engineering & Technology for providing the right academic guidance that made my task possible .

I would like to thank our Project Coordinator & Mentor **Dr. SANKAR K**, and all the staff members of Computer Science and Engineering for their support.

I am also grateful to my family and friends who provided me with every requirement throughout the course.

I would like to thank one and all who directly or indirectly helped me in completing the work successfully.

CONTENTS

1. Abstract	2
2. Introduction	3
2.1 Background and Motivation	3
2.2 Insider Threat Landscape	4
2.3 Research Objectives	5
2.4 Significance of Research	6
2.5 Report Organisation	7
3. Literature Survey	7
3.1 Historical Evolution	7
3.2 Rule-Based & Statistical Methods	9
3.3 Machine Learning Approaches	10
3.4 Deep Learning Architectures	11
3.5 (If exists in full doc) Hybrid Models	
3.6 Research Gaps Identified	17
4. Existing System	18
4.1 Overview	18
4.1.1 Manual Log Review	19
4.1.2 SIEM Systems	19
4.1.3 Data Loss Prevention	20
4.1.4 IAM & Least Privilege	21
4.1.5 UEBA Systems	21
4.2 Limitations	22
4.3 Need for Intelligent System	23
5. Problem Identification	24
5.1 Core Problem Statement	24
5.2 Specific Problems	24
5.3 Scope Boundary	26
6. Methodology	27
6.1 Dataset & Research Approach	27
6.2 System Architecture	27
6.3 Preprocessing & Feature Engg ..	29
6.3.1 Data Cleaning	29
6.3.2 Missing Value Handling	29
6.3.3 Standardisation	30
6.3.4 Dimensionality Reduction	30
6.4 Temporal Feature Engineering ..	30
6.5 Hybrid RF–LSTM Model	32
6.5.1 Random Forest	32

6.5.2 LSTM Model	33
6.5.3 Meta Classifier	34
6.6 Training & Optimisation	34
7. Proposed System	36
7.1 System Overview	36
7.2 Key Features	36
7.2.1 Data Fusion	36
7.2.2 Behavioural Baselines	37
7.2.3 Context-Aware Scoring	37
7.2.4 Alert System	38
7.2.5 Privacy Design	38
7.2.6 SIEM Integration	39
7.3 Experimental Results	39+
8. System Modules	~50
8.1 Module Overview	50
8.2 Log Acquisition Module	50
8.3 Data Preprocessing Module	51
8.4 Feature Engineering Module	52

ABSTRACT

Modern enterprises face an escalating category of cybersecurity risk that traditional perimeter-centric defences are fundamentally ill-equipped to address: the malicious insider. Unlike external adversaries who must breach network boundaries, insiders already possess authorised access, institutional knowledge, and the trust of their organisation. This positional advantage makes them uniquely dangerous and extraordinarily difficult to detect using conventional signature-based security tools such as firewalls, antivirus systems, and rule-based Security Information and Event Management (SIEM) platforms. The consequences of undetected insider incidents are severe, encompassing intellectual property theft, financial fraud, data sabotage, regulatory penalties, and irreversible reputational damage. This project presents the Malicious Insider Detection System (MIDS), a comprehensive, AI-powered behavioural security framework engineered to identify internal threats through the longitudinal analysis of high-resolution enterprise telemetry. The MIDS architecture is partitioned into four decoupled functional layers: a multi-source data acquisition module that ingests authentication logs, file-system metadata, network proxy records, email metadata, and device activity events; a rigorous preprocessing and feature engineering pipeline employing K-Nearest Neighbour (KNN) imputation, Z-score standardisation, Principal Component Analysis (PCA), and Recursive Feature Elimination (RFE); a hybrid machine learning engine combining a Random Forest ensemble classifier with a Long Short-Term Memory (LSTM) recurrent neural network through a late-fusion strategy; and a real-time alert generation interface producing context-enriched, prioritised security notifications. The Random Forest component identifies non-linear relationships among static behavioural features such as job role, access level, and session timing, while the LSTM component captures temporal dependencies within sequential event streams, enabling detection of sophisticated 'low-and-slow' exfiltration campaigns that unfold over weeks or months. The two components are integrated through a logistic regression meta-classifier that combines their complementary detection signals into a unified behavioural risk score. Validated against the industry-standard CERT Insider Threat Dataset v6.2 using stratified 5-fold cross-validation, the MIDS framework achieved a 96.4% Detection Rate (DR), 2 Precision of 0.92, Recall of 0.88, F1-Score of 0.90, AUC-ROC of 0.94, and a False Positive Rate (FPR) of only 1.1%. These results represent a 30%

reduction in false positive generation and a 20-percentage-point accuracy improvement over traditional rule-based SIEM systems. The framework is designed with 'privacy by design' principles embedded throughout, ensuring GDPR compliance through pseudonymisation, data minimisation, and role-based access controls, positioning MIDS as both a technically superior and ethically responsible solution for real-world enterprise deployment. Keywords: Insider Threat Detection, User Behaviour Analytics (UBA), Machine Learning, Cybersecurity, Anomaly Detection, Random Forest, LSTM, CERT Dataset, Behavioural Baseline, Enterprise Security, Data Exfiltration, Zero-Trust Architecture, Privacy by Design, GDPR Compliance, Ensemble Learning.

INTRODUCTION

2.1 Background and Motivation The modern enterprise operates within an intricate digital ecosystem where sensitive data assets, intellectual property, operational systems, and communication infrastructure are deeply intertwined. As organisations accelerate their digital transformation journeys — adopting cloud platforms, embracing remote and hybrid work models, integrating third-party services, and deploying Internet-of-Things devices across operational environments — the volume and sensitivity of data that must be protected have grown exponentially. Paradoxically, this same transformation has rendered conventional perimeter-centric security architectures increasingly obsolete, as the well-defined network boundaries they were designed to protect have dissolved into complex, distributed, and multi-cloud environments. Cybersecurity investment has historically followed the assumption that the most dangerous threats originate from external actors attempting to breach organisational defences. Consequently, enterprises have invested heavily in firewalls, intrusion detection and prevention systems (IDS/IPS), endpoint protection platforms, and network monitoring tools — all of which are fundamentally oriented toward detecting and blocking unauthorised access. Yet decades of security research and real-world incident data consistently demonstrate that some of the most damaging breaches are perpetrated not by external hackers overcoming perimeter controls, but by individuals who already possess the keys to the kingdom: authorised insiders. 3 The financial magnitude of this threat is staggering. Research from the Ponemon

Institute indicates that the average annualised cost of insider-led incidents has risen dramatically, with incidents involving credential theft averaging over USD 13 million annually per organisation. The 2022 Cost of Insider Threats Global Report revealed that insider threat incidents increased by 44% over the preceding two years, with the average time to contain an insider threat incident extending to 85 days. Beyond direct financial losses, insider incidents frequently result in regulatory penalties under GDPR, HIPAA, PCI-DSS, and sector-specific regulations, compounding the total cost of a breach. Perhaps most damaging are the long-term reputational consequences: when an insider breach becomes public knowledge, customer trust erosion and competitive disadvantage from intellectual property theft can threaten the very viability of an organisation. It is against this backdrop that the present research develops the Malicious Insider Detection System (MIDS) — a comprehensive, behaviour-centric framework that applies advanced machine learning and temporal sequence modelling to the problem of insider threat detection. By moving beyond the fundamental limitation of signature-based detection (which requires prior knowledge of what an attack looks like), MIDS establishes dynamic behavioural baselines for each monitored user and identifies statistically significant deviations that indicate malicious intent. This approach enables detection of both well-known threat patterns and novel attack strategies that have never been seen before, providing the adaptive security intelligence that modern enterprises urgently need.

2.2 The Insider Threat Landscape

Insider threats represent a uniquely challenging security problem because the threat actor is simultaneously the victim's trusted colleague, employee, or partner. This dual identity creates fundamental ambiguity: the same access rights, system knowledge, and behavioural patterns that make an insider valuable to an organisation also enable them to cause devastating harm if their intentions turn malicious. Understanding the taxonomy of insider threats is essential for designing effective detection strategies that can differentiate between the diverse motivations and mechanisms through which insider harm occurs.

Malicious Insiders — Individuals who deliberately misuse their authorised access for personal financial gain, competitive intelligence

gathering, retribution against a perceived organisational wrong, ideological motivation, or as recruited agents of external threat actors. This category encompasses a wide spectrum from disgruntled employees who sabotage systems before departure, to sophisticated corporate spies who systematically harvest proprietary research data over months or years. The deliberate nature of their activities often involves careful operational security measures to avoid detection, including accessing data during normal working hours, using legitimate applications for exfiltration, and mimicking normal usage patterns.

Negligent Insiders — Well-intentioned employees who inadvertently create security vulnerabilities through careless behaviour, poor security hygiene, susceptibility to social engineering attacks, or failure to comply with security policies. Common negligent insider scenarios include falling victim to spear-phishing attacks that install credential-stealing malware, misconfiguring cloud storage permissions that expose sensitive data publicly, sharing credentials with colleagues for convenience, and connecting personal, unmanaged devices to corporate networks. While lacking malicious intent, negligent insiders can cause damage comparable to deliberate attacks.

Compromised Insiders — Legitimate, well-intentioned employees whose accounts and credentials have been hijacked by external threat actors through credential theft, malware installation, or advanced persistent threat (APT) campaigns. Compromised insider scenarios are particularly dangerous because the external attacker inherits all the access privileges, organisational knowledge, and implicit trust associated with the legitimate account, enabling them to operate undetected for extended periods. Regardless of the specific threat category, insider incidents share a common characteristic that makes them fundamentally resistant to conventional security controls: the activities involved are performed using legitimate credentials, authorised applications, and within the scope of granted access rights. A database administrator who exfiltrates customer records has technically performed an authorised database query; an engineer who sends proprietary designs to a competitor via email has sent an email using their corporate account. These actions are indistinguishable from legitimate work activities at the individual event level, requiring

behavioural context and temporal pattern analysis to identify their malicious nature.

2.3 Research Objectives

This research is guided by six primary objectives, each addressing a specific gap in the current state of insider threat detection capabilities:

1. To design and implement a scalable, multi-tiered architecture for real-time insider threat detection that integrates behavioural telemetry from diverse enterprise log sources including Active Directory authentication records, file-system metadata, network proxy logs, email system metadata, and endpoint device activity records.
2. To develop a hybrid machine learning engine that combines the complementary capabilities of Random Forest ensemble classification and LSTM-based temporal sequence modelling, enabling simultaneous detection of overt policy violations and sophisticated multi-stage exfiltration campaigns. To implement and validate a rigorous preprocessing and feature engineering pipeline specifically designed to handle the inherent noise, sparsity, class imbalance, and high dimensionality characteristic of enterprise behavioural telemetry data. To empirically validate the MIDS framework against the industry-standard CERT Insider Threat Dataset v6.2 and benchmark its performance against a comprehensive set of baseline models including rule-based systems, isolation forests, and individual deep learning architectures. To design the system architecture with 'privacy by design' principles embedded throughout, ensuring that comprehensive insider threat monitoring can be achieved in full compliance with GDPR and other applicable data protection regulations. To demonstrate that the MIDS framework achieves the computational efficiency and processing throughput required for real-time deployment in large-scale enterprise environments generating millions of behavioural events per day. Significance of the Research The significance of this research extends across multiple dimensions. At the technical level, the hybrid RF-LSTM ensemble architecture represents a novel contribution to the field of insider threat detection, demonstrating that the integration of

static feature classification and temporal sequence modelling achieves detection performance superior to either approach in isolation. The late- fusion ensemble strategy, in which the Random Forest's classification output is incorporated as an additional feature vector for the LSTM, enables the temporal model to leverage both its own sequential pattern analysis and the RF's broader feature space assessment when generating final risk scores. At the operational level, MIDS addresses a critical gap between academic research and practical enterprise deployment. Many high-performing detection models proposed in academic literature fail to account for real-world constraints including computational resource limitations, data pipeline reliability requirements, analyst workflow integration, and the ethical and legal frameworks governing employee monitoring. MIDS is explicitly engineered for operational deployment, incorporating monitoring dashboard interfaces, SIEM integration APIs, and configurable alert management workflows that align with existing enterprise security operations centre (SOC) practices. At the societal level, the privacy-by-design architecture demonstrates that comprehensive insider threat monitoring and robust employee privacy protection are not mutually exclusive objectives. By implementing pseudonymisation, data minimisation, and strict need-to-know access controls as fundamental architectural features rather than compliance afterthoughts, MIDS provides a model for ethically responsible behavioural monitoring that maintains organisational trust while protecting against internal threats.

2.5 Report Organisation

The remainder of this report is structured as follows. Section 3 presents a comprehensive literature review spanning the historical evolution of insider threat detection from rule-based systems through modern deep learning architectures. Section 4 analyses the limitations of existing insider threat management approaches. Section 5 formally identifies and characterises the specific problems this research addresses. Section 6 details the complete methodology encompassing dataset selection, preprocessing pipeline design, and the hybrid ML engine architecture. Section 7 presents the proposed system design with comprehensive experimental results. Section 8 provides detailed descriptions of all six system modules. Section 9 covers implementation specifics including the technology stack

and data flow architecture. Section 10 presents the testing and validation strategy with full results. Section 11 provides in-depth analysis and discussion of results. Section 12 outlines the future research trajectory. Section 13 concludes with a summary of contributions, and Section 14 provides the complete reference list.

.Literature Survey: 3.1 Historical Evolution of Insider Threat Research

The academic investigation of insider threats has undergone profound transformations over the past two decades, mirroring broader advances in computing capability, data availability, and machine learning methodology. Understanding this evolution provides essential context for situating the MIDS framework within the current state of the art and clarifying the specific technical contributions this research makes to the field. 7

The earliest systematic efforts to address insider threats, emerging in the late 1990s and early 2000s, were grounded in the cybersecurity paradigms of the era: predominantly rule-based, signature-driven, and oriented toward the detection of discrete, identifiable events rather than continuous behavioural patterns. The foundational work of Anderson (1980) — decades before modern machine learning made behavioural analysis tractable — first articulated the conceptual distinction between external intrusions and insider misuse, proposing that the latter required fundamentally different detection strategies based on behavioural profiling rather than signature matching. This insight, while ahead of its time, established the conceptual foundation upon which all subsequent insider threat detection research is built. The establishment of the Carnegie Mellon Software Engineering Institute's CERT Insider Threat Center in 2001 represented a watershed moment for the field, creating an institutional focus for insider threat research and, crucially, providing the research community with standardised datasets against which detection systems could be benchmarked. The CERT Insider Threat Dataset — now in its sixth major version — remains the dominant benchmark for insider threat detection research, enabling meaningful cross-study performance comparisons that were previously impossible due to the absence of shared evaluation standards. The 2010s saw the application of increasingly sophisticated machine learning techniques to the insider threat detection problem. The availability of larger labelled datasets,

more powerful computing hardware, and more capable machine learning libraries enabled researchers to move beyond simple statistical thresholds and rule-based flags toward models that could learn complex, non-linear decision boundaries separating benign from malicious behavioural patterns. This period also saw the introduction of ensemble methods — combinations of multiple individual models whose aggregate predictions outperform any constituent model — as a dominant paradigm for achieving high accuracy while maintaining generalisability. The most recent wave of insider threat research, spanning from approximately 2017 to the present, has been characterised by the application of deep learning architectures — particularly recurrent neural networks and their LSTM variants — to exploit the inherently sequential nature of user behavioural data. These models learn representations of temporal patterns in event sequences that capture the multi-step nature of sophisticated insider attacks, enabling detection of threats that develop gradually over days, weeks, or months. The MIDS framework 8 contributes to this frontier by demonstrating that integrating LSTM temporal modelling with Random Forest ensemble classification in a unified hybrid architecture achieves superior performance to either approach alone.

3.2 Rule-Based and Statistical Approaches

The earliest computational approaches to insider threat detection relied on predefined rule libraries that flagged specific event combinations as potentially suspicious. These systems, often implemented as extensions to existing SIEM platforms, defined conditions such as 'user accessed more than N sensitive files within M hours outside normal working hours' or 'user copied more than X megabytes to a removable device'. While simple to implement and easy for security analysts to interpret, rule-based systems suffer from fundamental limitations that severely constrain their effectiveness in real-world deployment. The most critical limitation is inflexibility: rules must be manually authored by security engineers based on prior knowledge of known attack patterns, creating a perpetual lag between the emergence of novel threat behaviours and the development of corresponding detection logic. An attacker who is aware of the monitoring system's rule library can trivially circumvent detection by conducting exfiltration activities that do

not match any defined rule — for example, gradually accessing files at rates just below the threshold that would trigger an alert, or conducting illicit activities during hours that fall within their legitimate working window. Statistical anomaly detection approaches emerged as an attempt to address the inflexibility of rule-based systems by replacing hard-coded thresholds with statistically derived baselines. Methods such as Gaussian mixture models, probabilistic profiling, and graph-based anomaly detection establish mathematical representations of normal user behaviour from historical data and flag deviations from these representations as potential threats. Notable examples from the literature include Eberle and Holder's graph-based anomaly modelling, which represents user-system interactions as dynamic graphs and identifies structural deviations as potential insider activities, and the application of Hidden Markov Models to model the sequential structure of normal user workflows. However, statistical anomaly detection methods face their own set of challenges in real enterprise environments. The inherent variability of human behaviour — driven by project assignments, role changes, organisational restructuring, seasonal workload fluctuations, and individual working style differences — creates an extremely challenging signal-to-noise ratio for anomaly detection systems. In environments where users' legitimate activities are highly variable and unpredictable, statistical baselines that attempt to represent 'normal' behaviour inevitably produce high volumes of false positive alerts as legitimate but unusual activities are misclassified as potential threats. This 'alert fatigue' phenomenon is one of the most practically significant challenges in operational insider threat detection, as analysts overwhelmed by false alerts become desensitised and begin ignoring warnings, precisely when genuine threats may be occurring.

3.3 Machine Learning Based Detection

The application of supervised machine learning to insider threat detection represented a significant advance over both rule-based and statistical anomaly detection approaches, enabling models to learn complex, non-linear decision boundaries between benign and malicious behavioural patterns from labelled training data without requiring manual rule authorship. The seminal work of Salem et al. demonstrated that Support Vector Machines and Decision Tree

classifiers substantially outperform rule-based approaches when applied to the CERT Insider Threat Dataset, establishing the viability of supervised machine learning as a foundation for insider threat detection. Random Forest ensembles quickly became one of the most widely applied supervised learning methods for insider threat detection due to their combination of high predictive accuracy, natural handling of high-dimensional feature spaces, built-in feature importance estimation, and robustness to overfitting through bootstrap aggregation. The Random Forest's ensemble nature — aggregating predictions from hundreds of decorrelated decision trees — provides a natural mechanism for quantifying prediction uncertainty, which is particularly valuable in security contexts where the cost of false positives (unnecessary investigations) and false negatives (missed threats) must be carefully balanced. Unsupervised learning methods gained traction in contexts where the scarcity of labelled insider threat data makes supervised approaches impractical. The fundamental challenge of insider threat detection from a data perspective is severe class imbalance: genuine insider incidents are statistically rare events in the population of all user activities, often representing less than 0.1% of total behavioural events in large organisations. This imbalance makes it extremely difficult to collect sufficient labelled examples of malicious behaviour to train supervised classifiers effectively. K-means clustering, DBSCAN, and Isolation Forest algorithms offer alternative approaches that identify anomalous behavioural patterns without requiring labelled training examples, instead detecting users whose behaviour deviates significantly from that of their peers. The feature engineering decisions made prior to model training have been shown to exert enormous influence on the performance of machine learning models for insider threat detection. Research has consistently identified several categories of behavioural features as particularly discriminative: temporal features capturing the timing and scheduling of user activities relative to normal working hours; volumetric features measuring the quantity of data accessed, transferred, or modified; access pattern features characterising the types of resources a user interacts with; and peer comparison features that contextualise a user's activities relative to colleagues with similar roles. The

MIDS framework incorporates 47 carefully engineered features spanning all four categories, building on the most discriminative features identified across the existing literature.

3.4 Deep Learning Architectures

The integration of deep learning architectures into insider threat detection systems represents the current frontier of the field, motivated by two key observations: first, that the sequential nature of user behavioural data contains temporal dependencies that conventional machine learning methods cannot fully capture; and second, that the raw representational power of deep neural networks enables automatic feature learning from high-dimensional, heterogeneous input data without extensive manual feature engineering.

Recurrent Neural Networks (RNNs) and their most successful variant, Long Short-Term Memory (LSTM) networks, are particularly well-suited to insider threat detection because they are specifically designed to process sequential data and learn representations of temporal dependencies across arbitrary time intervals. The LSTM's gating mechanism — comprising forget, input, and output gates that regulate information flow through the network — enables it to selectively retain information about distant past events that remain relevant to current predictions while discarding irrelevant historical data, making it capable of detecting behavioural patterns that develop over days or weeks.

Convolutional Neural Networks (CNNs), originally developed for image recognition tasks, have been adapted for insider threat detection by treating temporal sequences of behavioural events as one-dimensional signals and applying convolutional filters to extract local temporal patterns. While CNNs offer computational efficiency advantages over RNN architectures, their fixed-length convolutional receptive fields limit their ability to capture long-range

3.6 Research Gaps Identified

The comprehensive review of existing insider threat detection literature reveals five critical gaps that directly motivate the MIDS research and inform its specific design decisions:

- • • Performance Degradation in Dynamic Environments: The overwhelming majority of published insider threat detection systems are evaluated exclusively in static laboratory settings using fixed historical datasets. Real enterprise environments are fundamentally dynamic — user roles change, projects evolve, organisational structures are restructured, and

legitimate behavioural patterns shift continuously. Systems trained on static historical data without mechanisms for continuous baseline adaptation rapidly become outdated, with detection performance degrading as the divergence between training-time and deployment time behavioural distributions increases. MIDS addresses this gap through rolling baseline updates with exponential decay weighting and periodic automated model retraining.

Temporal Blind Spots in Static Models: Many high-performing classification models published in the literature treat each behavioural observation window as an independent data point, ignoring the sequential context of the events that preceded it. This architectural choice makes these models inherently incapable of detecting 'low-and-slow' insider threats — sophisticated attacks deliberately designed to keep individual-window behavioural metrics below detection thresholds by spreading exfiltration activities across extended timeframes. MIDS addresses this gap through the LSTM temporal modelling component, which explicitly models dependencies across sequences of up to 30 consecutive observation windows.

Insufficient Privacy-Security Integration: The technical insider threat detection literature almost universally treats the system's monitoring capabilities as the primary design concern, with privacy implications addressed, if at all, as compliance afterthoughts rather than fundamental architectural requirements. This approach is increasingly untenable in regulatory environments governed by GDPR, 17 CCPA, and similar data protection frameworks. MIDS integrates privacy-preserving mechanisms — pseudonymisation, data minimisation, role-based access controls, and configurable data retention policies — as core architectural features, not optional add-ons.

• • 4.1 Limited Validation Diversity: Research in the field is dominated by evaluation against a single dataset — the CERT Insider Threat Dataset — which, while valuable, represents a specific simulation environment that may not fully capture the behavioural diversity of modern enterprise environments, particularly those incorporating cloud-native workflows, mobile device usage, and extensive third-party platform integrations. While MIDS validation also uses CERT v6.2 as the primary benchmark (to enable meaningful comparison with published results), the

framework's architecture is explicitly designed for extension to additional data sources and deployment contexts. Interpretability Deficit: Deep learning models that achieve high detection accuracy frequently function as black boxes that provide little insight into why specific activities were flagged as suspicious. This interpretability deficit has significant operational consequences: security analysts who cannot understand the reasoning behind an alert cannot effectively triage it, determine its severity, or initiate targeted investigations. MIDS addresses this gap through the Random Forest component's built-in feature importance scores, which are included in every generated alert package to provide analysts with human-interpretable evidence supporting each detection decision.

4. Existing System Overview

Before articulating the MIDS framework's design and capabilities, it is essential to thoroughly understand the existing ecosystem of technologies, processes, and practices through which organisations currently attempt to manage insider threats. This understanding reveals the specific limitations that motivate the MIDS research and enables a meaningful assessment of the improvements it delivers. The current insider threat management landscape is characterised by a collection of individually capable but collectively insufficient tools, each designed to address specific aspects of security risk but lacking the integrated, behavioural analysis capability required to effectively detect sophisticated insider threats.

18 The fundamental architectural challenge facing all existing insider threat management approaches is that they were designed in an era of well-defined network perimeters and relatively simple IT environments. The implicit assumption underlying most security tools — that legitimate users behave consistently and within narrow, predictable parameters — is increasingly invalid in the modern enterprise, where digital work environments are characterised by enormous individual variation, constant change, and complex multi-system interactions. As a result, tools that perform adequately in simple, static environments generate unmanageable volumes of false alerts in real-world enterprise deployments.

4.1.1 Human Security Personnel and Manual Log Review

The most traditional form of insider threat management relies on trained

security personnel conducting manual reviews of system logs, access records, user activity reports, and security event feeds. Security Operations Centre (SOC) analysts monitor dashboards, investigate flagged events, and conduct periodic audits of access control records and privileged user activities. While human judgment remains invaluable for interpreting complex behavioural contexts and making nuanced risk assessments, manual review processes are fundamentally unscalable in modern enterprises that generate terabytes of security telemetry daily. The limitations of manual review extend beyond simple volume concerns. Manual processes are inherently inconsistent, as different analysts apply different judgement criteria when evaluating similar events, creating unpredictable detection outcomes. Manual reviews are also extremely slow — the mean time to detect an insider threat through manual processes is frequently measured in months, providing ample time for significant damage to occur before detection. Furthermore, human reviewers are susceptible to cognitive biases, including anchoring bias (over-reliance on initial impressions), confirmation bias (selectively weighing evidence that confirms existing suspicions), and base rate neglect (failing to appropriately account for the rarity of genuine insider threats), all of which can significantly impair detection accuracy.

4.1.2 Rule-Based SIEM Systems

Security Information and Event Management (SIEM) platforms aggregate log data from diverse security tools and network infrastructure components, applying predefined correlation rules to identify suspicious event combinations that warrant investigation. Modern SIEM platforms such as Splunk Enterprise Security, IBM QRadar, and Microsoft Sentinel provide centralised visibility across the enterprise IT environment and offer sophisticated query languages and dashboarding capabilities that significantly enhance analyst productivity compared to manual log review. However, SIEM effectiveness for insider threat detection is fundamentally limited by the quality and completeness of their correlation rule libraries. Rules must be manually designed and maintained by experienced security engineers who possess both deep technical knowledge of the enterprise IT environment and a thorough understanding of insider threat attack patterns — a combination of expertise that is difficult to find and expensive to retain. The rule development

process is inherently reactive: new detection rules can only be written for attack patterns that security engineers are already aware of, creating a persistent lag between the emergence of novel threat techniques and the deployment of corresponding detection logic. In large enterprise environments, SIEM systems routinely generate thousands of false positive alerts per day, creating severe 'alert fatigue' among SOC analysts. Studies have shown that security teams receive so many alerts that analysts spend the vast majority of their time processing low-value false positives rather than investigating genuine threats. In the most extreme cases, alert volume becomes so overwhelming that analysts begin systematically ignoring all but the highest- severity alerts, creating dangerous blind spots precisely where sophisticated insider attacks may be operating below severity thresholds.

4.1.3 Data Loss Prevention Systems

Data Loss Prevention (DLP) systems monitor and control the movement of sensitive data across organisational boundaries, applying content inspection policies to identify and block unauthorised data transfers. DLP solutions typically operate at several control points: network DLP monitors data in transit through proxy servers and email gateways; endpoint DLP controls data movement on individual devices including USB transfers, clipboard operations, and application data access; and cloud DLP extends monitoring to cloud storage and collaboration platforms. DLP systems are valuable tools for preventing accidental data leakage by negligent insiders and for enforcing data handling policies, but they face significant limitations when confronting deliberate, sophisticated insider threats. Malicious insiders who are aware of DLP system configurations can employ numerous circumvention techniques: encrypting data before transfer to prevent content inspection, disguising sensitive files within innocuous-seeming formats, 20 fragmenting large data transfers into smaller pieces that individually fall below DLP size thresholds, using approved cloud storage services that are excluded from DLP monitoring, or exploiting application whitelisting to route exfiltration through trusted programs. Additionally, DLP systems' heavy reliance on content inspection patterns requires continuous maintenance to keep pace with new sensitive data types and formats.

4.1.4 Identity and Access Management with Least Privilege

Identity

and Access Management (IAM) frameworks implementing the Principle of Least Privilege (PoLP) restrict user access permissions to the minimum level required for their defined job function, limiting the potential damage that any single insider could cause if their access is misused. Combined with Privileged Access Management (PAM) solutions that enforce additional controls over administrative accounts, IAM represents an essential security layer in any comprehensive insider threat management strategy. However, IAM controls are fundamentally preventive rather than detective — they reduce the blast radius of an insider incident by limiting what a malicious insider can access, but they cannot detect misuse of legitimately granted permissions. A database administrator with authorised access to production customer databases can still exfiltrate sensitive records within the scope of their legitimate access rights without triggering any IAM alert. Furthermore, practical operational requirements frequently force compromises in least-privilege implementations: business continuity requirements, time-sensitive operational needs, and the complexity of maintaining fine-grained access controls across large, rapidly evolving IT environments mean that many users retain access privileges beyond their immediate operational requirements.

4.1.5 User and Entity Behaviour Analytics

User and Entity Behaviour Analytics (UEBA) platforms represent the most sophisticated existing approach to insider threat detection, applying statistical and machine learning methods to establish behavioural baselines and identify anomalous user activities. Commercial UEBA solutions from vendors including Splunk UEBA, Microsoft Sentinel UEBA, Exabeam, and Securonix incorporate multiple detection algorithms and pre-built use case libraries targeting common insider threat scenarios including data exfiltration, account compromise, and privilege escalation. Despite their sophistication, commercial UEBA platforms frequently underperform against sophisticated insider threats due to several limitations. ²¹ Many commercial UEBA systems apply relatively simple statistical methods — standard deviations from baseline means, peer group comparison — that lack the temporal modelling capability required to detect 'low-and-slow' threats. The ML models embedded in commercial platforms are typically trained on generic datasets that may not represent the specific

behavioural patterns of the customer's unique user population and IT environment, requiring extensive configuration and tuning for each deployment. Furthermore, the black-box nature of many UEBA algorithms makes it difficult for analysts to understand why specific activities were flagged, impairing effective triage and investigation.

4.2 Limitations of Existing Systems — Consolidated Analysis Drawing on the preceding analysis of individual existing approaches, the following consolidated limitations motivate the MIDS research: •••••

No Real-Time Longitudinal Behavioural Modelling: Existing tools analyse events in isolation or over short time windows without constructing longitudinal behavioural profiles that capture temporal patterns developing over weeks or months. This gap makes them blind to sophisticated multi-stage attacks.

Overwhelming False Positive Rates: Rule-based SIEM systems generate excessive false alert volumes, with industry research indicating that over 50% of all generated security alerts are false positives that consume analyst time without delivering security value. Alert fatigue is a critical operational problem.

Poor Adaptability to Legitimate Behavioural Change: Static rule sets and fixed anomaly thresholds cannot accommodate legitimate changes in user behaviour driven by role transitions, project changes, or organisational restructuring without extensive manual reconfiguration.

Dependence on Manually Maintained Rule Libraries: SIEM detection capabilities are constrained by the knowledge and time of security engineers who must manually author and maintain detection rules, creating permanent lag between emerging threats and deployed detection capabilities.

Insufficient Context Awareness: Most existing systems evaluate user activities without incorporating the organisational context required to distinguish between anomalous-but-legitimate activities (e.g., a system administrator conducting large-scale file operations) and genuinely suspicious activities by standard users.

Privacy and Compliance Risks: Many existing monitoring tools collect and retain excessive personally identifiable information without adequate anonymisation mechanisms, creating compliance risks under GDPR and other data protection regulations.

22 • **4.3 Limited Scalability:** Many academic and commercial insider threat detection solutions demonstrate

adequate performance in small-scale environments but fail to maintain performance under the data volumes characteristic of large enterprises. Need for an Intelligent Detection System The convergence of these limitations creates an urgent imperative for a next- generation insider threat detection framework that overcomes each of the deficiencies identified above. The required system must: construct dynamic, continuously-updated behavioural baselines for individual users that adapt to legitimate behavioural evolution; detect subtle, multi-stage anomalies spanning extended timeframes without requiring predefined attack signatures; incorporate organisational context that enables accurate distinction between legitimate and suspicious anomalous behaviour; minimise false positive alert generation through contextually informed probabilistic risk scoring; embed privacy-preserving mechanisms that enable comprehensive monitoring within applicable legal frameworks; and demonstrate the computational efficiency required for real-time deployment at enterprise scale. These requirements collectively define the design specification for the MIDS framework. 23 5. Problem

Identification 5.1 Core Problem Statement The fundamental problem addressed by this research is the critical deficiency in existing enterprise cybersecurity frameworks to effectively detect, classify, and respond to insider threats — security incidents perpetrated by individuals who possess authorised access to organisational systems, networks, and sensitive data assets. Unlike external threat actors who must overcome perimeter defences, malicious insiders exploit their inherent positional advantages within organisational trust boundaries to conduct damaging activities that remain effectively invisible to conventional security controls. The problem is compounded by the inherent ambiguity of insider behaviour: the same sequence of system interactions that constitutes malicious data exfiltration when performed by a disgruntled employee preparing to join a competitor may be entirely routine when performed by an authorised data analyst conducting legitimate business intelligence activities. This fundamental overlap between benign and malicious behavioural patterns — combined with the enormous diversity and variability of normal user behaviour across different roles, departments, and individual working styles

— demands a sophisticated, context-aware detection capability that can accurately distinguish between the two at acceptable false positive rates. The problem is further complicated by the adversarial nature of sophisticated insider threats. Unlike random system faults or external attacks that may follow predictable patterns, deliberate insider threats are conducted by individuals with intimate knowledge of the organisation's security monitoring capabilities, who can adapt their behaviour specifically to evade detection. This adversarial dynamic requires detection systems that learn flexible, generalisable representations of malicious behaviour rather than relying on brittle rules that a knowledgeable insider can trivially circumvent.

5.2 Specific Problems Identified

1. Siloed Security Tool Architecture: Existing security tools — firewalls, SIEM, DLP, IAM, UEBA — operate in organisational silos with limited data sharing and correlation between platforms. This fragmentation prevents the holistic behavioural correlation necessary to detect multi-stage insider attacks that span multiple system components and data sources. An attacker who spreads their activities across authentication systems, file servers, email platforms, and removable media — each

2. Individually below detection thresholds — exploits these detection blind spots created by siloed tool architectures. Absence of Temporal Behavioural Modelling: Current detection systems analyse security events as discrete, independent data points or within very short temporal windows, rather than as elements within continuous behavioural sequences extending over weeks or months. This architectural limitation makes it impossible to detect 'low-and-slow' exfiltration attacks where individual observations appear unremarkable but the temporal progression of behaviours reveals a clear pattern of malicious intent. Dataset Imbalance and Training Challenges: Insider threat incidents are statistically rare relative to normal user activities, creating severe class imbalance in training datasets. Naive model training on imbalanced data produces classifiers that achieve high overall accuracy by simply predicting 'benign' for all observations while completely failing to detect genuine threats. Addressing this challenge requires specialised sampling strategies (SMOTE), cost-sensitive learning, and carefully designed evaluation protocols that assess performance on the minority malicious class specifically.

Insufficient Contextual Enrichment: Raw system logs contain minimal contextual information. Without enrichment with organisational hierarchy data, user role profiles, project assignments, and peer group behavioural norms, even sophisticated machine learning models cannot distinguish between anomalous-but-legitimate activities explained by a user's specific role requirements and anomalous activities that indicate malicious intent. A security engineer accessing thousands of files on a production server is performing routine maintenance; the identical activity by an HR administrator is a serious anomaly.

Computational Scalability Constraints: Many high-performing detection models proposed in academic literature are computationally prohibitive for real-time deployment in large enterprises generating millions of behavioural events per day. Deep learning inference is computationally intensive, and the latency requirements for meaningful real-time threat detection — ideally detecting and alerting within minutes of suspicious activity rather than hours or days — impose strict computational budgets that many published architectures cannot meet on standard enterprise hardware.

Ethical and Legal Constraints on Employee Monitoring: Comprehensive insider threat monitoring requires the collection and analysis of sensitive employee behavioural data that raises significant legal and ethical concerns. GDPR Article 6 requires a lawful basis for processing personal data; GDPR Article 5(1)(c) requires data minimisation; and various national employment laws impose additional constraints on employee monitoring in different jurisdictions. Detection systems that fail to incorporate privacy-preserving mechanisms expose deploying organisations to substantial regulatory and legal liability.

7. 5.3 Alert Management and Analyst Workflow Integration: Even technically superior detection systems fail to deliver operational security value if their output cannot be effectively integrated into existing SOC analyst workflows. Alerts that lack supporting evidence, contextual enrichment, and prioritisation create cognitive overhead for analysts and impede effective triage. Detection systems must be designed from the ground up with the analyst user experience in mind, providing actionable, evidence-rich, prioritised output that enables rapid, informed investigation decisions.

Problem Scope Boundary This research specifically

addresses the detection of malicious insider activities within enterprise organisational environments using non-intrusive behavioural telemetry derived from system-generated logs, authentication records, and file- system metadata — data that organisations are already collecting for operational and compliance purposes and that does not require any additional monitoring infrastructure deployment on employee devices beyond standard log collection agents. The research scope explicitly excludes: physical security monitoring (camera footage, badge access analysis); communication content analysis (email content, instant message transcripts, browsing content); continuous biometric surveillance (keylogging, screenshot capture, webcam monitoring); and personal device monitoring beyond the enterprise network boundary. These exclusions reflect both the ethical constraints on intrusive employee monitoring and the practical reality that organisations operating under GDPR and similar regulations may face legal barriers to these more invasive monitoring approaches. The MIDS framework is validated against the CERT Insider Threat Dataset v6.2, which simulates realistic enterprise insider threat scenarios including data theft via removable media, intellectual property exfiltration via email, system sabotage through file deletion, and gradual data harvesting campaigns. The framework is designed for organisations with 100 to 100,000 users and is architected to accommodate the full range of enterprise IT environments from on-premises infrastructure to hybrid and multi-cloud deployments.

26 6. Methodology

6.1 Research Approach and Dataset

The MIDS development follows a systematic, evidence-driven research methodology structured across six sequential phases: (1) dataset acquisition and exploratory analysis, (2) preprocessing and feature engineering pipeline design, (3) hybrid model architecture design and training, (4) ensemble integration and meta-classifier optimisation, (5) real-time deployment architecture design, and (6) comprehensive performance evaluation and benchmarking against baseline systems. Each phase builds directly upon the outputs of the preceding phase, ensuring that design decisions at every level of the system are grounded in empirical evidence rather than theoretical assumptions. The primary validation dataset is the CERT Insider Threat Dataset version 6.2, published by the

Carnegie Mellon University Software Engineering Institute. This dataset is the most widely used and rigorously validated benchmark for insider threat detection research, providing synthetic but statistically realistic representations of enterprise user activities across five behavioural data modalities. The dataset encompasses 1,000 simulated users operating over an 18-month period within a realistic enterprise environment, generating approximately 32 million individual activity events distributed across logon/logoff authentication records, file system operation logs, USB device activity records, email metadata logs, and HTTP proxy access logs. The dataset includes carefully constructed malicious scenarios representing five distinct insider threat types: removable media data exfiltration, email-based intellectual property theft, system sabotage through unauthorised file deletion, 'low-and-slow' gradual data harvesting, and credential misuse through account sharing. The CERT v6.2 dataset presents several characteristics that make it a particularly valuable and challenging validation environment. The realistic class imbalance — — malicious activities constitute approximately 3-7% of total behavioural events requires careful handling to prevent model training from collapsing to a trivial all-benign prediction strategy. The five distinct threat scenarios test detection capability across qualitatively different attack patterns, ensuring that reported performance metrics reflect genuine detection capability rather than pattern memorisation. The 18-month time span enables evaluation of temporal modelling capabilities and allows assessment of how model performance evolves as the time distance between training and evaluation periods increases.

6.2 System Architecture Design

The MIDS framework is architected as a four-layer, microservices-based system designed for horizontal scalability, component independence, and minimal operational coupling between detection pipeline stages. This architectural philosophy reflects a core engineering principle: in enterprise security systems, resilience and maintainability are as critical as raw detection performance, since a highly accurate system that is brittle, difficult to maintain, or susceptible to data pipeline failures provides inadequate operational security value.

Layer 1 — Data Acquisition and Log Fusion:

The outermost layer collects and normalises raw telemetry from heterogeneous

enterprise log sources through a distributed agent-based collection architecture. Lightweight collection agents deployed on monitored endpoints capture security events in real time and forward them to a centralised Apache Kafka message broker cluster through encrypted, mutually authenticated TLS channels. The log fusion module normalises events from diverse sources — Windows Event Log, Squid Proxy, Microsoft Exchange tracking logs, Active Directory audit logs — into a unified behavioural schema, resolving timestamp inconsistencies, standardising field formats, and enriching raw events with organisational context data including the user's department, role tier, and direct manager from the HR system integration.

Layer 2 — Preprocessing and Feature Engineering: The second layer transforms the unified raw event stream into machine learning-ready feature vectors through a multi-stage processing pipeline implemented as a distributed Apache Spark Structured Streaming application. This layer handles data quality issues (missing values, duplicate events, malformed records), applies statistical normalisation to ensure uniform feature scales, performs dimensionality reduction to focus the model on the most discriminative signals, and aggregates individual events into temporal observation windows that serve as the basic unit of analysis for the detection engine.

Layer 3 — Hybrid ML Detection Engine: The core detection layer applies the trained RF-LSTM ensemble model to incoming feature vectors to generate continuous behavioural risk scores for each monitored user. The engine operates in two distinct modes: offline batch training mode, which periodically retrains the ensemble on updated behavioural data; and online inference mode, which processes incoming feature vectors through the trained model in real time. The inference pipeline is implemented as a low-latency REST API service, enabling flexible integration with diverse enterprise security platforms.

Layer 4 — Alert Generation and Response Interface: The outermost operational layer converts model risk scores into actionable, context-enriched security alerts suitable for direct consumption by SOC analysts. The alert generation module aggregates supporting evidence from the operational data store, computes peer group comparison statistics, retrieves the user's organisational profile, and assembles a comprehensive alert package containing all information required

for informed triage and investigation without requiring analysts to conduct manual log correlation.

6.3 Preprocessing and Feature Engineering

Enterprise-level raw behavioural telemetry is characterised by heterogeneity, noise, sparsity, and high dimensionality — properties that pose significant challenges for machine learning systems expecting clean, consistently formatted, appropriately scaled input representations. The MIDS preprocessing pipeline addresses these challenges through a carefully sequenced series of data transformation steps, each designed to correct a specific class of data quality issue without introducing statistical biases that could impair detection performance.

6.3.1 Data Quality Assessment and Cleaning

The preprocessing pipeline begins with comprehensive data quality assessment that characterises the volume and distribution of quality issues in each ingested data batch. Missing value rates are computed per-feature and per-user, identifying systematic data gaps that may indicate collection agent failures requiring remediation. Duplicate event detection removes redundant records resulting from network retransmission or collection agent restarts, ensuring that each genuine event is counted exactly once. Temporal consistency validation ensures that event timestamps are monotonically increasing within each user session, rejecting records with implausible timestamps that may indicate clock synchronisation failures.

6.3.2 Missing Value Imputation

Missing values in enterprise telemetry arise from diverse causes: network connectivity interruptions preventing log forwarding, collection agent restarts, system maintenance windows that suppress logging, and application-specific logging gaps. The MIDS framework employs K-Nearest Neighbours (KNN) imputation with $k=5$ to estimate missing attribute values based on the behavioural profiles of the five most similar users, as measured by Euclidean distance in the space of non-missing features. KNN imputation preserves the multivariate correlation structure of behavioural data — ensuring that imputed values reflect the characteristic patterns of similar users rather than population averages — which is critical for maintaining the discriminative signal content of the feature representation. KNN neighbour models are recomputed monthly to account for the evolution of the user behavioural distribution over time.

6.3.3 Z-Score

Standardisation Continuous behavioural features exhibit vastly different natural scales: total bytes transferred may range from kilobytes to gigabytes, while failed authentication count typically ranges from 0 to 20. Without standardisation, high-magnitude features would numerically dominate the machine learning model's objective function, effectively suppressing the contribution of low-magnitude but informationally significant features. The MIDS framework applies Z-score standardisation — transforming each feature to have zero mean and unit variance — using parameters (mean and standard deviation) estimated from the training dataset and applied without re-estimation to validation and test data to prevent information leakage between evaluation splits. The standardised value $z = (x - \mu) / \sigma$, where x is the raw observation, μ is the training set mean, and σ is the training set standard deviation.

6.3.4 Dimensionality Reduction

The initial feature space of the MIDS preprocessing pipeline encompasses over 200 candidate features derived from raw log attributes. Feeding this full-dimensional feature space directly to the machine learning engine would exacerbate the 'curse of dimensionality' — the well-documented phenomenon whereby model performance degrades as the ratio of features to training samples increases, leading to overfitting and poor generalisation. The MIDS framework applies a two-stage dimensionality reduction approach: first, Principal Component Analysis (PCA) identifies the orthogonal directions of maximum variance in the feature space, retaining the minimum number of principal components that collectively explain 95% of total dataset variance; second, Recursive Feature Elimination (RFE) iteratively removes the feature with the smallest absolute coefficient in a trained logistic regression model until a target feature count (47 in the final implementation) is reached.

6.4 Temporal Feature Engineering with Sliding Windows

A defining characteristic of the MIDS feature engineering approach is the application of temporal aggregation through overlapping sliding windows that transform individual event records into summary statistical representations of user behaviour over configurable time periods. Rather than treating each system event as an independent observation — which would require classifying millions of raw events per day and would make temporal pattern detection

impossible — the sliding window approach compresses event streams into compact, information-rich feature vectors that capture the statistical properties of user behaviour within each window. The default window configuration uses 24-hour observation windows with a 6- hour sliding step, meaning that each window overlaps with the three preceding windows and three following windows. This overlap structure ensures continuity — a behavioural anomaly that begins near the end of one window will also be represented in the following windows, ensuring that partial-window anomalies are not missed due to window boundary effects. For each 24-hour window, 47 behavioural features are computed across six categories: • • • • •

Authentication Behaviour Features (10): Total logon events, failed logon count, failed logon ratio, mean session duration, after-hours logon proportion, unique workstation count, distinct IP address count, concurrent session maximum, weekend logon indicator, and privileged account usage indicator. File System Interaction Features (12): Total file access events, distinct files accessed count, sensitive directory access count, sensitive directory access ratio, file modification count, file deletion count, file creation count, data volume accessed (GB), cross-department file access count, executable file access count, bulk file copy indicator, and after-hours file access proportion. Network Activity Features (8): Total outbound connections, external domain count, bandwidth consumed (GB), cloud storage access count, peer-to-peer application usage indicator, Tor/anonymisation service access indicator, high-risk domain category access count, and geographic destination diversity score. Email Behaviour Features (9): Total emails sent, external recipient count, external recipient ratio, attachment count, large attachment indicator (>10MB), mass email indicator, CC/BCC diversity score, email forwarding rule change indicator, and after-hours email activity proportion. Device Usage Features (6): USB insertion event count, total data transferred to removable media (GB), device diversity count, screen capture tool usage indicator, clipboard data volume, and personal device connection indicator. 31 • Contextual and Peer Comparison Features (2): After-hours activity overall ratio, and peer group deviation score (Z-score of user's risk indicators relative to their departmental peer group). The temporal sequence

fed to the LSTM component consists of 30 consecutive daily observation windows (representing approximately one month of behavioural history), enabling the model to detect gradual behavioural drift across a full monthly cycle. This sequence length was determined through empirical ablation testing, with detection performance plateauing beyond 30 days of historical context for the CERT v6.2 dataset scenarios.

6.5 Hybrid Random Forest–LSTM Predictive Engine

The core detection capability of the MIDS framework is delivered through a hybrid ensemble architecture that integrates two complementary machine learning paradigms. This architectural choice reflects a fundamental observation about the multi-scale temporal structure of insider threats: overt policy violations (e.g., immediate bulk data exfiltration, simultaneous access to multiple restricted systems) are detectable from individual observation windows, while sophisticated 'low-and-slow' attacks require analysis of behavioural trajectories spanning multiple consecutive windows. No single modelling approach is optimally suited to detecting both threat categories simultaneously; the hybrid architecture achieves this by assigning each component to its domain of comparative advantage.

6.5.1 Random Forest Ensemble Component

The Random Forest (RF) component serves as the initial behavioural screening layer, applying an ensemble of 200 decision trees to the static feature vector extracted from each observation window to generate a window-level malicious behaviour probability estimate. Each decision tree is trained on a bootstrap sample of the training dataset using a random subset of features at each split — specifically, the square root of the total feature count, as is conventional for classification Random Forests — ensuring that individual trees are sufficiently diverse to provide meaningful ensemble diversity when their predictions are aggregated through majority voting. The RF uses the Gini Impurity criterion to evaluate candidate split points at each tree node. For a node containing a mixture of n_0 benign and n_1 malicious observations, the Gini Impurity $G = 1 - (p_0^2 + p_1^2)$, where p_0 and p_1 are the proportions of benign and malicious observations respectively. Optimal splits minimise the weighted average Gini Impurity of the resulting child nodes, effectively identifying feature thresholds that most cleanly

separate benign from malicious observations. This criterion is preferred over information gain (entropy) for insider threat detection due to its computational efficiency and comparable empirical performance. A critical advantage of the Random Forest for the MIDS application is its natural provision of feature importance estimates: by tracking how much each feature contributes to Gini Impurity reduction across all trees in the ensemble, the RF produces a ranked importance score for every input feature. These importance scores serve dual purposes: they guide the alert generation module in identifying the specific behavioural dimensions most responsible for an elevated risk score (enabling interpretable analyst communications), and they provide feedback to the feature engineering pipeline to focus future feature development on the most discriminative signal categories.

6.5.2 LSTM Temporal Modelling Component

The Long Short-Term Memory (LSTM) network processes sequences of 30 consecutive daily feature vectors to capture temporal dependencies that cannot be detected from individual observation windows. The LSTM architecture employs two stacked LSTM layers with 128 hidden units each, followed by a dropout regularisation layer (rate=0.3) and a dense output layer with sigmoid activation producing a sequence-level malicious behaviour probability estimate. The two-layer LSTM architecture enables learning of hierarchical temporal representations: the first layer captures short-range dependencies (day-to-day behavioural variations), while the second layer integrates these short-range patterns into longer-range temporal abstractions that capture gradual behavioural drift. The LSTM processes each input sequence through its gating mechanism: the forget gate $f_t = \text{sigmoid}(W_f \cdot [h_{t-1}, x_t] + b_f)$ determines which historical cell state information to discard at each time step; the input gate $i_t = \text{sigmoid}(W_i \cdot [h_{t-1}, x_t] + b_i)$ controls what new information from the current time step to incorporate; and the output gate $o_t = \text{sigmoid}(W_o \cdot [h_{t-1}, x_t] + b_o)$ determines what information from the updated cell state to pass to the next time step's hidden state. This selective memory mechanism enables the LSTM to maintain relevant historical context across all 30 time steps of the input sequence without suffering from the vanishing gradient problem that limits standard

RNN architectures. 33 The LSTM input sequence for each user evaluation includes, at each of the 30 time steps, the user's 47 standardised behavioural features plus the Random Forest's window-level malicious probability estimate for that window (48 total inputs per time step). This integration strategy — incorporating the RF's assessment as an additional LSTM input feature rather than combining RF and LSTM outputs only at the final prediction stage — enables the temporal model to track not only the raw behavioural features but also the RF's instantaneous risk assessment over time, allowing it to detect patterns of gradually escalating RF scores that might individually fall below alert thresholds but collectively indicate a developing insider threat.

6.5.3 Meta-Classifer Ensemble Integration

The final detection decision is generated by a logistic regression meta-classifier trained on the combined outputs of the RF window-level predictions and the LSTM sequence-level prediction. Using a held-out validation set, the meta-classifier learns the optimal weights to assign to each component's prediction based on their individual calibration and error correlation patterns. The logistic regression output — a probability between 0 and 1 representing the final risk score — is translated into a four-tier risk classification: Low (0-0.25), Medium (0.26-0.50), High (0.51-0.75), and Critical (0.76-1.0), with configurable thresholds that can be tuned per user tier to balance detection sensitivity against operational alert volume.

6.6 Training Strategy and Hyperparameter Optimisation

Given the severe class imbalance in the CERT v6.2 dataset, the MIDS training strategy incorporates several techniques specifically designed to prevent the model from collapsing to a trivial all-benign prediction strategy. Synthetic Minority Over-sampling Technique (SMOTE) generates synthetic training examples for the minority malicious class by interpolating between existing malicious observations in the feature space, increasing the effective malicious class representation to a 30:70 benign-to-malicious ratio in the training dataset. Cost-sensitive learning assigns a class weight inversely proportional to class frequency in the training set (approximately 15x higher weight for malicious class observations) to the loss function, ensuring that misclassification of malicious observations incurs substantially higher training penalties than

misclassification of benign observations. Hyperparameter optimisation is conducted through Bayesian optimisation using the Optuna framework with 100 optimisation trials evaluated on a stratified 34 validation set. The Bayesian approach models the hyperparameter-to- performance mapping as a Gaussian process, directing search toward the most promising regions of the hyperparameter space based on previous trial results — significantly more efficient than grid search or random search for high- dimensional hyperparameter spaces. Key hyperparameters optimised include RF tree count (optimal: 200), maximum tree depth (optimal: 22), minimum samples per leaf (optimal: 5), LSTM hidden units (optimal: 128), LSTM dropout rate (optimal: 0.3), and Adam optimiser learning rate (optimal: 0.0008). 35

7. Proposed System

7.1 System Overview

The Malicious Insider Detection System (MIDS) represents a comprehensive, AI-powered behavioural security framework that transitions enterprise insider threat management from a reactive, rule-based paradigm to a proactive, behaviour- centric paradigm grounded in advanced machine learning. The system is designed from the ground up as an operational enterprise security tool rather than an academic proof-of-concept, prioritising the practical requirements of real-world deployment: computational efficiency for real-time processing at scale, integration with existing enterprise security infrastructure, analyst workflow alignment, explainability of detection decisions, and ethical compliance with data protection regulations. MIDS achieves comprehensive insider threat coverage by analysing five distinct categories of enterprise behavioural telemetry simultaneously, enabling detection of threat patterns that span multiple systems and data sources. The system's hybrid RF-LSTM detection engine captures both instantaneous policy violations visible in individual observation windows and gradual behavioural drift that only becomes detectable through longitudinal temporal analysis. The context- enrichment layer ensures that detection decisions incorporate the organisational knowledge required to distinguish between legitimate anomalous activities and genuinely suspicious behaviour, dramatically reducing the false positive rate compared to context-agnostic detection approaches.

7.2 Key Features of the Proposed System

7.2.1 Multi-Source Behavioural Data Fusion

The MIDS data

fusion layer integrates behavioural signals from five enterprise data sources — Active Directory authentication logs, Windows file system audit logs, network proxy logs, email server metadata, and endpoint device activity records — into a unified behavioural schema that enables cross-source correlation analysis. This multi-modal fusion capability is critical for detecting sophisticated insider attacks that deliberately distribute their activities across multiple systems to remain below single-source detection thresholds. For example, a pre-departure data theft scenario might involve: after-hours authentication to the corporate VPN (authentication log), access to large volumes of engineering drawings on a shared file server (file system log), establishment of a new personal email forwarding rule (email log), and transfer of a large compressed archive to a USB drive (device 36 log). No single log source reveals the full picture; only cross-source behavioural fusion exposes the pattern. The log fusion module implements a unified event schema with standardised field names, data types, and temporal representations, enabling downstream processing components to work with a consistent data representation regardless of the diversity of original log formats. Organisational context enrichment — mapping user identifiers to department, role tier, manager chain, and project assignment data from the HR information system — is applied at the fusion layer, ensuring that all downstream processing is contextually informed from the earliest stage of the data pipeline.

7.2.2 Dynamic Individualised Behavioural Baselines

MIDS constructs and continuously updates individualised behavioural baselines for each of the 1,000+ monitored users, capturing the statistical distribution of each user's normal behavioural patterns across all 47 engineered features. Unlike static population-level thresholds that apply uniform detection criteria to all users regardless of their specific role and working patterns, individualised baselines enable the detection engine to accurately characterise what 'normal' means for each specific user and flag deviations from that user-specific norm. Baselines are initialised from the first 90 days of each user's historical behavioural data and updated continuously using exponential decay weighting — a technique that gives recent observations greater influence on baseline statistics than older observations while maintaining continuity with established

patterns. The decay parameter (half-life: 30 days) is selected to balance two competing requirements: sensitivity to legitimate, gradual behavioural evolution (e.g., a user who takes on new responsibilities and legitimately begins accessing different system resources) and detection of sudden anomalous changes (e.g., a user who abruptly begins downloading large volumes of data immediately before announcing their resignation).

7.2.3 Context-Aware Risk Scoring

The MIDS risk scoring system incorporates multiple layers of organisational context to ensure that risk scores accurately reflect the security significance of detected behavioural anomalies rather than simply reflecting statistical deviation from population norms. Role-aware sensitivity adjustment applies different detection thresholds to different user role tiers — system administrators who legitimately perform bulk file operations receive appropriately calibrated baselines that prevent their routine maintenance activities from triggering false alerts, while standard users performing identical activities are correctly flagged as highly anomalous. Peer group comparison provides an additional contextual dimension by computing each user's behavioural deviation relative to their departmental peer group — colleagues with similar roles, access levels, and work responsibilities. A financial analyst whose data access volume is statistically normal for their individual baseline but dramatically elevated relative to their peer group of 50 other financial analysts presents a qualitatively different risk profile than an analyst whose elevated access is consistent with both their personal baseline and their peer group norms. Peer group deviation scores are incorporated as explicit input features to the detection engine, enriching its contextual awareness beyond individual baseline comparison.

7.2.4 Real-Time Prioritised Alerting

The MIDS alert generation module produces continuous, real-time risk scores on a 6-hour evaluation cycle, with urgent escalation protocols for Critical-tier risk score events that enable near-instantaneous analyst notification for the highest-confidence detections. Alert packages are assembled automatically with comprehensive supporting evidence including the specific behavioural features most responsible for the elevated risk score (derived from Random Forest feature importance scores), the raw log events underlying each anomalous feature, historical risk score trends for

the user over the preceding 30 days, peer group comparison statistics, and the user's full organisational profile. Alert prioritisation uses a multi-factor scoring formula that combines the model's detection probability estimate with the user's access level (higher-privilege users receive proportionally higher priority scores for equivalent detection probabilities), the temporal trajectory of the user's risk scores (accelerating risk score growth is weighted more heavily than stable elevated scores), and the business sensitivity of the specific resources accessed. This multi-dimensional prioritisation ensures that the most operationally significant threats consistently receive the earliest analyst attention, maximising the security value delivered per analyst-hour of investigation time.

7.2.5 Privacy-by-Design Architecture

Privacy protection is implemented as a fundamental architectural principle throughout the MIDS system rather than as a compliance overlay applied to an existing monitoring architecture. At the data ingestion layer, a pseudonymisation service maps real user identifiers — Active Directory Security Identifiers (SIDs), 38 email addresses, employee ID numbers — to cryptographically random UUID-based pseudonyms using a deterministic mapping stored in a Hardware Security Module (HSM) accessible only through a strictly audited API. All data flowing through the preprocessing, feature engineering, and ML detection layers operates exclusively on pseudonymised identifiers, ensuring that sensitive personal identity information is never exposed to the ML processing pipeline. The de-pseudonymisation API — which maps a pseudonymous UUID back to the real user identity for alert investigation purposes — enforces strict access controls requiring multi-factor authentication, role-based authorisation limited to designated security investigators, written justification logging for every de-pseudonymisation request, and real-time notification to a privacy officer of all identity disclosure events. This architecture ensures that the vast majority of the MIDS system's operations — data collection, feature computation, ML inference, risk scoring — are performed on anonymous representations, with personal identity disclosure occurring only in the specific, audited, necessity-justified context of active security incident investigation.

7.2.6 SIEM and SOAR Platform Integration

MIDS is designed for seamless integration with

existing enterprise security infrastructure through standardised API interfaces and widely-supported data exchange formats. Alert packages are exported in Common Event Format (CEF) and Log Event Enhanced Format (LEEF) for ingestion by SIEM platforms including Splunk Enterprise Security, IBM QRadar, and Microsoft Sentinel. REST API webhooks enable direct integration with Security Orchestration, Automation, and Response (SOAR) platforms including Palo Alto XSOAR and IBM Resilient, enabling automated response workflow initiation for high-confidence threat detections. The risk score feed API enables integration with identity governance platforms to trigger dynamic access scope reviews for high- risk users.

7.3 Experimental Results

The MIDS framework was subjected to rigorous empirical evaluation using an 80/10/10 train/validation/test data split stratified by user and incident type, with final performance assessment conducted through stratified 5-fold cross- validation. All reported metrics represent performance on held-out test data that was not used in any aspect of model training or hyperparameter optimisation.

39 Table 4: MIDS System Modules Overview

8.2 Log Acquisition Module — Detailed Description

The Log Acquisition Module is the foundational data collection layer of the MIDS pipeline, responsible for capturing comprehensive, low-latency behavioural telemetry from all monitored enterprise systems while minimising performance impact on production endpoints. The module implements a push-based, agent-driven collection architecture in which lightweight Python agents deployed on endpoint devices capture security events in real time and forward them to the central Kafka message broker through compressed, encrypted TCP connections. Collection agents are designed with a minimal resource footprint — consuming less than 0.5% CPU and 50MB RAM per endpoint under normal enterprise workload conditions — to ensure that security monitoring does not adversely affect monitored system performance. Agents implement local buffering with configurable maximum buffer sizes and retry logic, ensuring that telemetry captured during network interruptions is forwarded reliably when connectivity is restored rather than being permanently lost. All agent-to-broker communications use TLS 1.3 with mutual certificate authentication, preventing both eavesdropping on

sensitive behavioural telemetry and injection of fraudulent events by malicious insiders attempting to evade detection. The module supports collection from six primary data sources: Windows Security Event Log (collecting authentication events 4624/4625/4647/4648, privileged operation events 4672/4673, and account management events 4720/4725/4726); Windows File System Audit Log (object access events 4656/4663); Microsoft 50 Exchange Server Message Tracking Log; Squid HTTP/HTTPS Proxy Access Log; Symantec/Windows Defender Endpoint Protection Device Control Log; and Active Directory replication logs for credential-related changes. A modular collector plugin architecture enables straightforward extension to additional log sources as enterprise IT environments evolve. A critical operational consideration for the Log Acquisition Module is the handling of log source availability failures, which are a routine occurrence in large enterprise environments due to planned maintenance windows, network interruptions, and application restarts. The module implements graceful degradation logic that continues detection pipeline operation in the absence of individual log sources, flagging the data gap in processed records to ensure that downstream components appropriately discount confidence in detection decisions made with incomplete data. Automated alerting to the MIDS operations team is triggered when log source availability falls below configurable thresholds, enabling timely remediation of collection gaps.

8.3 Data Preprocessing Module — Detailed Description

The Data Preprocessing Module implements the complete multi-stage data quality and normalisation pipeline as a distributed Apache Spark Structured Streaming application, processing incoming log events from the Kafka broker in micro-batches with a configurable processing interval of 5 minutes. The micro-batch processing model balances two competing requirements: the latency requirement for near-real-time processing (event records should be incorporated into the feature engineering pipeline within minutes of their generation at the source endpoint) and the efficiency requirement for economical use of computational resources (processing individual events one-by-one would incur excessive overhead per event). Each processing micro-batch undergoes a standardised seven-step cleaning sequence. Step 1 applies format validation — ensuring

that each record contains all required fields with appropriate data types — rejecting and logging malformed records for operational review. Step 2 applies temporal consistency validation — verifying that event timestamps are monotonically increasing within user sessions and fall within the expected operational time range — rejecting records with anomalous timestamps. Step 3 applies duplicate detection using a sliding window deduplication algorithm that identifies records with identical (user_id, event_type, resource_id, timestamp) tuples within a 60-second window, retaining only the first occurrence. 51 Step 4 applies the KNN missing value imputation algorithm using neighbour models maintained in memory and updated monthly. Step 5 applies Z-score standardisation using training-set-derived normalisation parameters. Step 6 applies outlier capping — replacing extreme feature values (beyond the 99.9th percentile of the training distribution) with the capping threshold — to prevent rare extreme events from numerically dominating normalised feature vectors. Step 7 applies the schema normalisation mapping, translating source-specific field names and value formats into the unified behavioural schema used by all downstream pipeline components. The preprocessing module maintains rolling statistics that are used both for data quality monitoring and for adaptive baseline calibration: per-source event volume statistics detect log source failures; per-user missing value rate statistics identify collection gaps; and distribution shift statistics track when the current behavioural distribution deviates significantly from the training-time distribution, triggering automated model retraining when drift exceeds configured thresholds.

8.4 Feature Engineering Module — Detailed Description

The Feature Engineering Module transforms the stream of clean, standardised individual event records produced by the Preprocessing Module into the structured feature vectors and temporal sequences required by the ML Detection Engine. The module maintains active sliding window state for all monitored users in memory, updating each user's window statistics in real time as new event records arrive and publishing completed window feature vectors to the feature vector Kafka topic at the end of each 6-hour sliding step. For each active 24-hour observation window, the module maintains running accumulators for each of the 47 engineered features, implemented

as online update algorithms that incorporate new events incrementally without requiring reprocessing of previously seen events. When a window closes (determined by the arrival of events with timestamps beyond the window boundary), the accumulated feature values are finalised, standardised using the current normalisation parameters, and combined with the contextual features derived from the user's organisational profile to produce the complete 47-dimensional feature vector for that window. The peer group deviation features — which contextualise each user's behavioural metrics relative to their departmental peer group — are computed by the Feature Engineering Module using a maintained index of current 30-day rolling statistics for all users in each peer group category. For each user's observation window, the 52 module computes the Z-score of each of the user's 47 raw (pre-standardisation) feature values relative to the corresponding distribution across their peer group, providing a rich representation of behavioural deviation that is grounded in the specific operational context of the user's role. The LSTM temporal sequences are assembled by the Feature Engineering Module by retrieving the 30 most recent completed window feature vectors for each user from the operational database and packaging them as a three-dimensional tensor (30 time steps $\times$ 48 features including RF estimates) suitable for direct input to the LSTM inference API. Sequence assembly is performed on-demand at each 6-hour evaluation cycle rather than continuously, ensuring that sequences always incorporate the most recent completed observation window.

8.5 Hybrid ML Detection Engine — Detailed Description

The Hybrid ML Detection Engine is the computational core of the MIDS framework, implementing the Random Forest and LSTM model inference pipelines and the meta-classifier ensemble integration. The engine operates as a microservice cluster with separate service instances dedicated to RF inference, LSTM inference, and meta-classifier inference, enabling independent horizontal scaling of each component based on its specific computational requirements and load patterns. The RF inference service is implemented as a multi-threaded Flask application serving a Scikit-learn Random Forest model loaded into memory at service startup. Each inference request submits a 47-dimensional feature

vector and receives in response the ensemble's malicious probability estimate along with the top-10 feature importance scores — the 10 features that most contributed to the prediction — computed using SHAP (SHapley Additive exPlanations) values for improved interpretability over standard Mean Decrease Impurity importance. SHAP values provide a locally accurate, game-theory-grounded explanation of each feature's contribution to a specific prediction, enabling meaningful interpretation of individual alerts even when the overall model operates as a black box. The LSTM inference service is implemented using TensorFlow Serving, Google's production-grade model serving infrastructure for TensorFlow models. TensorFlow Serving handles model versioning, A/B testing between model versions during rolling updates, request batching for throughput optimisation, and health monitoring with automatic recovery from inference failures. The LSTM model is compiled with TensorFlow's XLA compiler for maximum inference throughput on CPU infrastructure, achieving mean single-sequence inference latency of 280 milliseconds — well within the operational latency budget. The model training infrastructure is implemented as a scheduled Apache Airflow DAG that executes weekly, automatically retrieving the most recent 90 days of processed behavioural data, applying the SMOTE oversampling and cost-sensitive training strategy, executing Bayesian hyperparameter optimisation, training the final models, evaluating performance on the held-out test partition, and publishing approved model versions to the MLflow model registry. Automated model deployment to the inference services occurs when newly trained models meet or exceed the minimum quality thresholds (Precision ≥ 0.88 , Recall ≥ 0.84 , AUC-ROC ≥ 0.90) established to prevent deployment of degraded models.

8.6 Alert Generation Module — Detailed Description

The Alert Generation Module is the operational bridge between the detection engine's technical risk score outputs and the security analyst's investigation workflow. The module monitors the continuous stream of risk scores from the Detection Engine's meta-classifier output and assembles comprehensive alert packages for risk score events that exceed configured tier thresholds. Alert assembly involves querying multiple data sources: the Elasticsearch log store for

supporting raw event evidence, the operational PostgreSQL database for the user's 30-day risk score history, the HR integration API for the user's current organisational profile, and the peer group statistics cache for the user's peer comparison data. Alert packages are structured around a standardised JSON schema that provides SIEM platforms, SOAR automation, and the SOC Dashboard with a consistent, machine-parseable alert format. The schema includes a summary section with key detection metadata (timestamp, user pseudonym/identity post-authorisation, risk score, alert tier), a behavioural evidence section listing the top-5 anomalous features with their current values, historical baseline values, and deviation magnitudes, a timeline section showing the user's risk score trend over the preceding 30 days, a peer comparison section showing the user's rank within their peer group for each anomalous feature, and a recommended investigation actions section providing analysts with prioritised investigation steps based on the specific anomalous feature combination detected. Alert prioritisation within the Alert Generation Module uses a multi-factor scoring formula: $\text{Alert Priority} = (\text{Detection Probability} \times 0.40) + (\text{Access Level 54 Weight} \times 0.25) + (\text{Risk Score Velocity} \times 0.20) + (\text{Resource Sensitivity Score} \times 0.15)$. Access Level Weight assigns higher priority to privileged accounts (system administrators, database administrators, C-level executives) whose potential blast radius in an insider incident is proportionally larger. Risk Score Velocity measures the rate of change of the user's risk score over the preceding 7 days, giving higher priority to rapidly escalating risk patterns than to stable elevated risk. Resource Sensitivity Score reflects the business value classification of the specific resources accessed, giving higher priority to detections involving crown jewel data assets.

8.7 Security Operations Dashboard — Detailed Description

The Security Operations Dashboard provides the human-facing operational interface through which SOC analysts consume MIDS detection outputs, manage investigation workflows, and monitor system health. The dashboard is implemented as a React.js single-page application with a Node.js GraphQL API backend, WebSocket connections for real-time data updates, and a PostgreSQL operational database. D3.js provides the data visualisation layer, rendering interactive behavioural

timeline charts, user risk ranking heat maps, and alert investigation evidence views. The dashboard's primary operational views include: the User Risk Leaderboard, which displays current risk scores for all monitored users sorted by risk tier with real-time updates pushed via WebSocket connections; the Alert Investigation Workspace, which provides analysts with the full alert package details, supporting log evidence, investigation note-taking functionality, and case management workflow for tracking alert disposition; the Behavioural Analytics Explorer, which enables ad-hoc temporal analysis of any monitored user's behavioural history across all 47 features with configurable time range selection; the Peer Group Analytics view, showing comparative risk distributions across organisational units; and the System Health Monitor, displaying pipeline processing throughput, model inference latency, log source availability, and detection model performance statistics. The Dashboard implements role-based access controls that restrict analyst access to alert and investigation data according to their defined security role. Tier 1 analysts can view alerts and perform initial triage; Tier 2 analysts can access detailed behavioural evidence and perform de-pseudonymisation requests with mandatory justification; security managers can access aggregated risk statistics and system performance dashboards; and MIDS administrators can access system.

55 10. Results Analysis and Discussion 10.1 Overall Performance Analysis The empirical validation of the MIDS framework against the CERT Insider Threat Dataset v6.2 demonstrates consistently superior performance across all evaluation metrics compared to every baseline model tested, confirming the core hypothesis that a hybrid RF-LSTM ensemble architecture enriched with organisational context outperforms both individual model components and established baseline approaches. The 96.4% overall accuracy and 0.94 AUC- ROC score achieved by MIDS position it among the highest-performing insider threat detection systems reported in the peer-reviewed literature, achieved through a computationally efficient architecture suitable for real-time enterprise deployment. The precision-recall balance achieved by MIDS — 0.92 precision and 0.88 recall with F1-score 0.90 — reflects a carefully tuned trade-off between detection sensitivity

and operational specificity. The decision to optimise the detection threshold for F1-score rather than recall alone reflects the operational reality that both missed detections and false positive alerts carry significant costs in enterprise security environments. A higher recall threshold (e.g., 0.95) would catch more genuine threats but would also generate substantially more false positive alerts that consume analyst time and erode confidence in the detection system. The selected operating point represents the Pareto-optimal balance between these competing objectives for the CERT v6.2 dataset, though the threshold can be adjusted per deployment based on the specific risk tolerance and analyst capacity of the deploying organisation. The 1.1% False Positive Rate is particularly operationally significant. In a 10,000- user enterprise environment operating continuously, a 1.1% FPR implies approximately 110 false positive alerts per monitoring cycle (one per user per cycle at the base rate) — a manageable investigation workload for a competent SOC team. The comparable rule-based SIEM baseline's 12.4% FPR would generate approximately 1,240 false positive alerts per cycle — more than 11 times the workload — overwhelming analyst capacity and creating the alert fatigue conditions under which genuine threats are most likely to be missed.

10.2 Comparative Performance Discussion

Examining the performance differential between the full MIDS ensemble and its 74 individual component models provides important insight into the specific delivered by the hybrid architecture. The LSTM-only model achieves 93.2% accuracy compared to 96.4% for the full ensemble — a 3.2 percentage point gap that represents a substantial relative improvement in detection capability. The Random Forest-only model achieves 91.8% accuracy — a 4.6 percentage point gap below the full ensemble. These differentials confirm that the RF and LSTM components capture meaningfully different and complementary aspects of malicious insider behaviour that neither captures alone. The RF component's primary detection advantage lies in its ability to identify overt, instantaneous policy violations visible within individual observation windows: a user accessing an unusually large number of sensitive files within a single day, authenticating from multiple simultaneous workstations, or transferring an anomalously large data volume to a removable device. These behaviours are detectable from the static feature snapshot of a

single window without temporal context. The LSTM component's primary detection advantage lies in its ability to identify gradual behavioural drift across sequences of 30 consecutive windows: a user whose per-window access volume incrementally increases over 4 weeks from normal to highly anomalous levels, or whose after-hours activity percentage steadily rises in the weeks leading up to a planned data exfiltration event. These patterns are completely invisible to the RF component operating on individual windows but constitute clear, detectable signals for the LSTM's temporal model. The 30% reduction in False Positive Rate achieved by MIDS compared to the best-performing baseline (Isolation Forest: 8.2% FPR versus MIDS: 1.1% FPR) is primarily attributable to the organisational context enrichment component. The ablation study confirms this attribution: removing the context enrichment increases the FPR from 1.1% to approximately 3.4% — a 3-fold increase — as the model loses the ability to distinguish between high-volume activities that are anomalous in absolute terms but entirely normal for users in specific high-privilege roles, and genuinely suspicious high-volume activities by standard users whose role does not justify elevated data access patterns.

10.3 Threat Scenario Analysis

The scenario-stratified performance results reveal important insights about the MIDS framework's differential detection capabilities across the five distinct threat scenarios present in the CERT v6.2 dataset. The highest detection rates are achieved for removable media exfiltration (98.2%) and system sabotage (97.4%) — scenarios that produce clear, distinctive behavioural signatures observable 76 within individual observation windows (dramatic USB usage volume spikes and anomalous file deletion events respectively) and therefore benefit most from the RF component's strong window-level classification capability. Email-based intellectual property theft achieves 96.8% detection rate, reflecting the distinctive combination of anomalous behavioural signals — elevated external recipient count, large attachment volume, personal email forwarding rule creation — that provide strong discriminative evidence even within a single observation window when combined with contextual information about the user's normal email communication patterns. The lowest detection rate — 89.3% for low-and-slow gradual data harvesting — reflects the fundamental challenge of detecting threats specifically designed to evade single-window detection by distributing exfiltration activities across extended timeframes. The 18.4-hour mean detection lag for this scenario (compared to 2.8-6.1 hours for

other scenarios) reflects the accumulated evidence requirement: the LSTM needs to process sufficient consecutive windows of gradually escalating behavioural anomaly before the temporal pattern becomes sufficiently clear for high-confidence detection. Despite this lower initial detection rate, longitudinal analysis of the low-and-slow scenario reveals that 78% of incidents not detected within their first evaluation cycle are subsequently detected in a later cycle as behavioural evidence accumulates — ultimately achieving a 94.1% lifetime detection rate for this most challenging threat scenario. Credential sharing and account misuse achieves 94.7% detection rate through a distinctive combination of simultaneous authentication event anomalies (multiple concurrent active sessions, geographically impossible location transitions) and subtle behavioural pattern mismatches between the credential owner's established behavioural baseline and the actual activities performed by the credential borrower. The latter signal — detectable only through comparison with the established individual user baseline — highlights the critical importance of individualised baseline construction for detecting sophisticated credential-based insider threat scenarios.

10.4 Real-Time Performance Discussion

The system performance testing results confirm that MIDS achieves the computational throughput and latency profile required for real-time deployment in enterprise environments at 10,000-user scale. The 18.4-minute mean end-to-end alert latency — from event generation at the source endpoint to alert availability in the SOC Dashboard — falls comfortably within the operational requirement of 30 minutes for Medium and above risk tier events, providing security analysts with actionable intelligence within a timeframe that enables meaningful containment of ongoing insider incidents before significant damage has occurred. The demonstrated linear horizontal scaling — throughput scales proportionally with the addition of processing nodes — confirms that MIDS can accommodate enterprise growth without architectural changes, simply by adding compute capacity to the Kubernetes cluster. The 99.7% system availability achieved during the 30-day continuous load test exceeds the 99.5% SLA requirement, with all unplanned downtime attributable to Kafka broker leader elections during simulated network partition tests — a known, addressable operational issue that can be mitigated through Kafka broker configuration optimisation.

10.5 Limitations and Constraints

Despite the strong empirical results, several limitations constrain the current MIDS framework's effectiveness in real-world

deployment scenarios: • • • Cold Start Period: The system requires a minimum of 90 days of historical behavioural data to establish reliable individual user baselines. New employees, recently onboarded contractors, and users who have undergone significant role changes cannot be effectively monitored during this initial baseline establishment period, creating a potential detection gap. This limitation can be partially mitigated by initialising baselines from peer group statistics rather than individual history, but peer-group-initialised baselines are inherently less accurate than individually calibrated baselines. Adversarial Evasion Vulnerability: The current MIDS implementation does not explicitly account for sophisticated insider adversaries who are aware of the monitoring system's architecture and deliberately modify their behaviour to evade detection. A well-informed insider could potentially defeat the baseline-based detection by gradually shifting their behaviour over months to 'train' the adaptive baseline to accept abnormal activities as normal, then escalating to higher-volume exfiltration once the baseline has been sufficiently corrupted. Dataset Representativeness: All evaluation was conducted on the CERT Insider Threat Dataset, which, while the field's most established benchmark, represents a specific simulation environment from 2013 that may not fully capture the behavioural diversity of modern enterprise environments including cloud-native 78 • SaaS workflows, mobile device usage, and remote work patterns that have become dominant since the dataset's creation. Model Interpretability: While the Random Forest's SHAP-based feature importance scores provide meaningful alert enrichment, the LSTM component's detection reasoning is not directly interpretable, limiting analysts' ability to understand why specific temporal patterns triggered detections. Developing LSTM- specific explanation methods for time-series anomaly detection remains an active research challenge. 79 11. Future Work and Enhancements 11.1 Planned Technical Enhancements 11.1.1 Natural Language Processing Integration The current MIDS implementation analyses behavioural metadata (email recipient counts, attachment frequencies, subject line length) without examining the semantic content of communications. A critical limitation of this approach is that it cannot detect pre-attack behavioural indicators that manifest primarily in communication content: expressions of professional dissatisfaction or hostility toward the organisation in internal communications, responses to external recruitment solicitations from competitors, or the gradual transmission of sensitive technical

knowledge through seemingly innocuous explanatory emails to external contacts. Future MIDS iterations will incorporate Natural Language Processing (NLP) pipeline components for sentiment analysis of email and instant messaging content, topic modelling to identify communications referencing sensitive subjects (competitor names, acquisition targets, proprietary technical concepts), and entity extraction to flag communications containing references to sensitive data assets or key personnel. NLP analysis will be activated only for users whose behavioural risk scores exceed the Medium threshold, implementing a graduated monitoring intensity that applies intensive content analysis only where behavioural indicators already suggest elevated risk — balancing detection efficacy with employee privacy considerations. The NLP pipeline will leverage transformer-based language models fine-tuned on domain-specific corpora reflecting the organisation's communication vocabulary and document taxonomy. The fine-tuning approach is preferred over generic pre-trained models because insider threat-related communication patterns are highly domain-specific — the linguistic signals of pre-departure data theft in a financial services firm differ substantially from those in a pharmaceutical research organisation — and domain-adapted models achieve substantially better precision on these specialised detection tasks.

11.1.2 Continuous Biometric Authentication

To address the challenge of detecting credential theft and account sharing — scenarios where a legitimate user's credentials are actively used by an unauthorised individual — future MIDS versions will incorporate passive biometric continuous authentication using behavioural biometrics including 80 keystroke dynamics (the characteristic patterns of typing speed, key hold duration, and inter-key timing that are unique to individual users) and mouse movement dynamics (characteristic cursor movement speeds, click patterns, and scroll behaviours). These behavioural biometrics are collected non-intrusively through browser extensions and endpoint agents without requiring any specialised hardware, providing a continuous authentication signal that identifies when the physical individual operating a session differs from the authenticated account's established typing and interaction profile. The continuous authentication model will be implemented as an additional LSTM-based component that processes sequences of biometric event records to maintain a real-time confidence score representing the probability that the currently active session is being operated by the account's legitimate owner. When continuous

authentication confidence drops below a configurable threshold — indicating potential session hijacking or credential sharing — the behavioural risk score for that session is automatically elevated, triggering additional monitoring intensity and potential analyst review.

11.1.3 Graph Neural Network User Relationship Modelling The current MIDS detection paradigm focuses exclusively on individual user behavioural anomalies, treating each user's activities as independent of their colleagues' behaviour. This individual-centric approach cannot detect coordinated multi-user insider threat conspiracies — scenarios where multiple recruited or compromised employees collaborate on a data exfiltration campaign, with each participant's individual contribution remaining below single-user detection thresholds. Detecting these coordinated attacks requires modelling the organisational social network and identifying anomalous communication, collaboration, and resource access patterns involving groups of users. Future MIDS research will explore Graph Neural Network (GNN) architectures that represent the organisational communication and collaboration network as a dynamic graph, with users as nodes and communication/collaboration events as directed, weighted edges. GNN message-passing algorithms will enable the model to propagate risk signals through the graph structure, identifying clusters of mutually connected users whose collective behavioural patterns suggest coordinated activity. Temporal GNN architectures, which model the evolution of graph structure over time, will enable detection of collusion patterns that develop gradually as participants incrementally increase their coordination.

11.1.4 Cloud-Native and SaaS Platform Integration
81 The current MIDS data acquisition layer focuses on traditional on-premises enterprise systems — Active Directory, Windows file servers, on-premises email servers, network proxy servers. As organisations continue migrating critical workloads to cloud platforms and SaaS applications, comprehensive insider threat monitoring requires extending telemetry coverage to cloud-native log sources. Planned cloud integrations include Microsoft 365 Unified Audit Log (covering SharePoint Online, Microsoft Teams, OneDrive for Business, and Azure Active Directory activities); AWS CloudTrail (covering all API-level activities across the full AWS service catalogue); Google Workspace Admin Console audit logs; Salesforce Shield Event Monitoring; GitHub Enterprise audit logs for developer activities; and Workday HCM audit logs for HR data access. Each cloud platform integration introduces

unique data modelling challenges — diverse log schemas, platform-specific access patterns, and role taxonomies that differ substantially from traditional on-premises environments. The cloud integration development programme will address these challenges through platform-specific log normalisation modules that translate cloud-native audit log formats into the MIDS unified behavioural schema, enabling cross-platform behavioural correlation that detects threats spanning both on-premises and cloud environments in the hybrid IT architectures that characterise modern enterprises.

11.1.5 Autonomous Response Capabilities

The current MIDS operational model positions the system as a detection and alerting tool that generates prioritised security intelligence for human analyst review, with all response actions requiring explicit analyst authorisation. While this human-in-the-loop design is appropriate for the current maturity level and provides important safeguards against automated response errors, it introduces response latency that may prove costly in high-velocity insider threat scenarios where data exfiltration can occur within minutes. Future MIDS development will introduce tiered autonomous response capabilities for high-certainty threat scenarios, implemented with stringent safeguards to minimise the risk of erroneous automated actions. At confidence levels above 0.95 (Critical tier with supporting SHAP evidence consensus), the system will be empowered to immediately trigger automated response actions including: session suspension (terminating the active authenticated session while preserving forensic artefacts); dynamic access scope restriction (automatically narrowing the user's access permissions to a read-only profile pending analyst review); automated evidence preservation (capturing a forensic snapshot of the user's current session state and recent log history); and privileged account quarantine (temporarily disabling privileged administrative access for accounts exhibiting Critical-tier risk scores). All automated response actions will be reversible by an authorised analyst within a configurable grace period, providing a safety net against false-positive-induced operational disruption.

11.2 Research Extensions

- 7.
- 8.
- 9.
- 10.
- 11.

Adversarial Machine Learning Robustness: Developing formal adversarial robustness guarantees for behavioural anomaly detection models and implementing certified defences against adaptive insider threat actors who attempt to manipulate their behavioural data to evade detection.

Adversarial training methods that expose the model to synthetically generated evasion attack examples during training may

improve robustness against adaptive adversaries. Federated Learning for Privacy-Preserving Collaboration: Investigating federated learning architectures that enable multiple organisations to collaboratively train more generalisable insider threat detection models by sharing gradient updates rather than sensitive behavioural data. Federated learning could substantially improve detection of cross-organisational insider threat campaigns — a growing concern in interconnected supply chain environments — without compromising the privacy of any individual organisation's employee data. Explainable AI for Temporal Anomaly Detection: Developing post-hoc explanation methods specifically designed for LSTM-based temporal sequence anomaly detection, providing security analysts with human-interpretable explanations of why specific temporal behavioural patterns triggered detections. Time-series saliency methods — analogous to image saliency maps that highlight the image regions most responsible for a classification decision — could identify the specific time steps and features that most influenced the LSTM's detection decision. Real-World Enterprise Dataset Validation: Conducting validation studies on real enterprise behavioural datasets (with appropriate ethical approvals and privacy protections) to assess MIDS performance in actual deployment environments and identify domain-specific challenges not captured by the synthetic CERT v6.2 dataset. Collaboration with enterprise security research partners would enable collection of anonymised validation datasets that reflect modern cloud-native working patterns. Longitudinal Model Drift Characterisation: Conducting long-term empirical studies tracking MIDS detection performance over periods of 2-5 years in production deployment, characterising the rate and nature of performance degradation as 83

12. Conclusion

12.1 Summary of Research Contributions

This research has presented the complete design, implementation, and empirical validation of the Malicious Insider Detection System (MIDS), a comprehensive AI-powered behavioural security framework that advances the state of the art in enterprise insider threat detection across four primary technical dimensions. Taken together, these contributions establish MIDS as both a significant academic contribution to the field of cybersecurity research and a practically deployable enterprise security solution that addresses critical limitations of existing insider threat management approaches.

Contribution 1 — Hybrid Ensemble Architecture: The development of a novel hybrid RF-LSTM ensemble architecture that integrates the

complementary capabilities of Random Forest ensemble classification (for static window-level behavioural screening) and LSTM temporal sequence modelling (for detection of gradually evolving multi-stage threats). The late-fusion ensemble strategy — incorporating RF classification outputs as LSTM input features — enables the temporal model to leverage both its own sequential analysis and the RF's broader feature space assessment, achieving 96.4% accuracy and 0.94 AUC-ROC performance that exceeds both individual component models and all established baseline approaches by statistically significant margins.

Contribution 2 — Comprehensive Preprocessing Pipeline: The design, implementation, and empirical validation of a rigorous multi-stage preprocessing pipeline specifically engineered for enterprise behavioural telemetry, incorporating KNN missing value imputation, Z-score standardisation, outlier capping, PCA dimensionality reduction, and temporal sliding window aggregation. The ablation study demonstrated that this preprocessing pipeline contributes up to 8.3 percentage points to overall detection accuracy — making data engineering the single most important factor in MIDS detection performance, ahead of model architecture choices.

Contribution 3 — Context-Aware Detection Framework: The integration of organisational hierarchy context enrichment and peer group comparison statistics as explicit detection features, enabling the MIDS detection engine to accurately distinguish between anomalous-but-legitimate activities driven by role requirements and genuinely suspicious activities that warrant investigation. This 84 context-aware approach contributes 2.6 percentage points to accuracy (the largest 85 single feature engineering contribution) and reduces the False Positive Rate by approximately 3-fold compared to context-agnostic detection.

Contribution 4 — Privacy-by-Design Architecture: The design and implementation of a comprehensive privacy-preserving monitoring architecture that enables enterprise-grade insider threat detection while maintaining full GDPR compliance through pseudonymisation at the data ingestion layer, data minimisation through automated lifecycle management, and strict need-to-know de-pseudonymisation access controls. This contribution demonstrates that comprehensive security monitoring and robust employee privacy protection are complementary rather than competing objectives when privacy mechanisms are designed as fundamental architectural features rather than compliance afterthoughts.

12.2 Key Findings

The experimental results establish several important findings for the insider

threat detection research community and enterprise security practitioners: • • • • Temporal modelling is the most impactful architectural choice for insider threat detection: the ablation study demonstrated that removing the temporal sliding window aggregation — reverting to event-level classification — causes an 18.2 percentage point accuracy drop, dramatically larger than the impact of any other single component. Effective insider threat detection fundamentally requires longitudinal behavioural analysis. Ensemble integration of RF and LSTM achieves supralinear performance gains: the full RF-LSTM ensemble outperforms the better individual component (LSTM, 93.2%) by 3.2 percentage points, confirming that the ensemble integration captures genuinely complementary detection signals that neither component captures alone. Data preprocessing contributes more to detection performance than model architecture: the combined contribution of the preprocessing pipeline components (up to 15.3 percentage points for the most impactful combination of preprocessing steps removed) substantially exceeds the contribution of the model architecture choice (4.6 percentage points for RF-only versus full ensemble). Investment in data engineering delivers disproportionate detection performance returns. False positive rate reduction is achievable without sacrificing recall: MIDS achieves a 1.1% False Positive Rate (compared to 12.4% for rule-based baseline) while maintaining 0.88 recall (compared to 0.55 for rule-based baseline), demonstrating that the traditional precision-recall trade-off can be significantly improved through context-aware, organisationally-enriched detection approaches.

Real-time enterprise deployment at 10,000-user scale is computationally feasible: the performance testing results confirm that MIDS maintains all SLA targets under simulated 10,000-user load, with 18.4-minute mean end-to-end alert latency and 99.7% system availability, establishing the computational viability of sophisticated ML-based insider threat detection in production enterprise environments. Broader Impact and Significance The MIDS framework's significance extends beyond its immediate technical contributions to the field of insider threat detection research. By demonstrating that privacy-preserving design principles can be successfully integrated into a high-performance security monitoring system, MIDS provides a template for addressing one of the most persistent tensions in enterprise security: the conflict between the organisation's security imperative to monitor user activities

and the legal and ethical obligations to protect employee privacy. As data protection regulations become increasingly stringent globally, security solutions that fail to address this tension will face growing legal and reputational barriers to deployment. MIDS demonstrates that these objectives can be harmonised through thoughtful architectural design. The framework's modular, microservices-based architecture and open API design enable deployment across diverse enterprise environments without vendor lock-in or proprietary infrastructure dependencies. This openness is an important consideration for organisations that must maintain flexibility in their security tool choices and avoid single-vendor dependency in critical security infrastructure. The framework's extensibility — supporting incremental addition of new data sources, detection models, and response capabilities without disrupting existing detection operations — ensures long-term adaptability to evolving enterprise IT environments and emerging threat landscapes.

12.4 Concluding Remarks

As organisational digital transformation accelerates and the traditional boundary between trusted insiders and external threat actors continues to blur — through supply chain integrations, remote work, contractor relationships, and cloud platform dependencies — the ability to detect and respond to insider threats with speed, accuracy, and privacy sensitivity will become an increasingly central component of enterprise cybersecurity resilience. This research contributes a validated, deployable, and ethically responsible framework that organisations can leverage as a foundation for building this capability.

87 The MIDS framework, its implementation artifacts, the comprehensive evaluation protocol developed in this research, and the detailed architectural documentation contained in this report are prepared for contribution to the open-source cybersecurity research community, supporting ongoing academic investigation and enabling practitioners to build upon this foundation in addressing the continuously evolving insider threat challenge. The research team remains committed to the iterative development of MIDS through the planned future enhancements described in Section 12, with the ultimate objective of establishing MIDS as a proactive, autonomous, and universally deployable enterprise insider threat defence platform.

88

13. References

Foundational Concepts and Surveys [1] [2] [3] [4] [5] [6] [7]
 Cappelli, D. M., Moore, A. P., & Trzeciak, R. F. (2012). *The CERT Guide to Insider Threats: How to Prevent, Detect, and Respond to Information Technology Crimes*. Addison-Wesley Professional, Boston,

MA. Hunker, J., & Probst, C. W. (2011). Insiders and Insider Threats — An Introduction to the Special Issue of the Journal of Wireless Mobile Networks, Ubiquitous Computing, and Dependable Applications. *Journal of Wireless Mobile Networks, Ubiquitous Computing, and Dependable Applications*, 2(1), 1-8.

Homoliak, I., Toffalini, F., Guarnieri, E., Payer, U., & Ochoa, M. (2019). Insight into Insiders and IT: A Survey of Insider Threat Detection, Algorithms, and Datasets. *Future Generation Computer Systems*, 92, 1030- 1050.

Bhatt, G., Goundar, S., & Chand, K. (2021). Insider Threat Detection: A Comprehensive Survey of Datasets and Machine Learning Techniques. *IEEE Access*, 9, 101462-101481.

Agrafiotis, I., Nurse, J. R., Goldsmith, M., Creese, S., & Upton, D. (2018). A Taxonomy of Cyber-Physical Threats and Controls in the Smart Grid. *Journal of Cybersecurity*, 4(1), tyx022.

Liu, L., De Vel, O., Han, Q. L., Lughofer, E., & Peng, J. (2018). A Survey of Insider Threat Detection: Methods, Datasets, and Challenges. *Journal of Physics: Conference Series*, 1069, 012021.

Salem, M. B., Hershkop, S., & Stolfo, S. J. (2008). A Survey of Insider Attack Detection Research. In *Insider Attack and Cyber Security: Beyond the Hacker* (pp. 69-90). Springer, New York.

Data Acquisition and Behavioural Datasets [8] [9] Glasser, J., & Lindauer, B. (2013). Bridging the Gap: A Pragmatic Approach to Generating Insider Threat Data. In *Proceedings of the 2013 IEEE Security and Privacy Workshops* (pp. 98-104). IEEE.

Legg, P. A., Buckley, O., Hodges, D. J., & Creese, S. (2017). Visualizing and Detecting Insider Threats using Continuous Behavioral Monitoring. *Security and Communication Networks*, 2017, Article ID 5381059.

89 [10] [11] [12] [13] Eldardiry, H., Sricharan, K., & Brdiczka, O. (2013). Multi-source Analysis for Insider Threat Detection. In *Proceedings of the 2013 IEEE Conference on Intelligence and Security Informatics* (pp. 14-19). IEEE.

Gheyas, I. A., & Abdallah, A. E. (2016). Detection and Prediction of Insider Threats to Cyber Security: A Systematic Literature Survey and Meta-Analysis. *Big Data Analytics*, 1(1), 6.

Lindauer, B., Glasser, J., & Rosen, M. (2014). Generating Synthetic Insider Threat Data: Variations and Refinements for Multiple Scenarios. In *Proceedings of the IEEE Conference on Intelligence and Security Informatics* (pp. 97-102). IEEE.

Azaria, A., Richardson, A., & Kraus, S. (2014). Behavioral Analysis for Insider Threat Detection: Methods and Challenges. *Journal of Information Security and Applications*, 19(4-5), 335-346.

Preprocessing, Normalisation, and Feature Engineering [14] Chandola, V., Banerjee,

A., & Kumar, V. (2009). Anomaly Detection: A Survey. *ACM Computing Surveys*, 41(3), Article 15. [15] Yuan, F., Cao, Y., Shang, Y., & Liu, Y. (2018). Insider Threat Detection with Deep Neural Network. In *Proceedings of the 2018 IEEE International Conference on Computational Science* (pp. 189-201). Springer. [16] Cui, L., & Yu, B. (2020). Feature Selection and Performance Comparison of Insider Threat Detection. *Journal of Computer Research and Development*, 57(3), 565-577. [17] Sarkar, S., Kumar, S., & Sanyal, S. (2020). A Review on User Behavior Analytics in Cybersecurity: Methods, Applications, and Challenges. *International Journal of Computer Applications*, 174(8), 1-7. [18] Rashid, A., & Al-Diri, B. (2018). A Proposed Framework for Preprocessing High-Velocity Network Logs for Insider Threat Detection. *International Journal of Cybersecurity and Digital Forensics*, 7(2), 134- 148. [19] Kim, J., & Park, N. (2019). Context-Aware Behavioural Profiling for Insider Threat Detection Using Role-Based Access Analysis. *Journal of Information Systems Security*, 15(2), 67-89. 90 Machine Learning and Deep Learning Models [20] Tuor, A., Kaplan, S., Hutchinson, B., & Nichols, N. (2017). Deep Learning for Unsupervised Insider Threat Detection in Structured Cybersecurity Data. In *Proceedings of the 31st AAAI Conference on Artificial Intelligence* [21] [22] [23] [24] [25] *Workshop on Artificial Intelligence for Cybersecurity* (pp. 224-231). Liu, J., Liu, X., & Zhang, Y. (2019). An Insider Threat Detection Method Based on LSTM Neural Network. In *Proceedings of the IEEE 4th International Conference on Computer and Communication Systems* (pp. 570-574). IEEE. Zhang, Y., & Pan, L. (2018). Ensemble Learning for Insider Threat Detection in Enterprise Networks. In *Proceedings of the IEEE Third International Conference on Data Science in Cyberspace* (pp. 55-62). IEEE. Meng, Y., Liu, W., & Xu, J. (2020). Detection of Insider Threats using Isolation Forest and Behavioural Profiling. *IEEE Systems Journal*, 14(4), 3389-3399. Le, D. C., & Nuri, N. (2018). Convolutional Neural Networks for Insider Threat Detection in Enterprise Environments. In *Proceedings of the IEEE Symposium on Security and Privacy Workshops* (pp. 25-32). IEEE. Bin, G., & Shuhui, H. (2019). Sequence Modeling for Insider Threat Detection using Gated Recurrent Units. *Journal of Computer Security*, 27(4), 445-469. Real-Time Monitoring and Future Trends [26] Al-Mhiqani, M. N., Ahmad, R., & Abdhab, Z. (2020). A Real-time Insider Threat Detection Framework for Critical Information Infrastructures. *International Journal of Advanced*

Computer Science and Applications, 11(3), 294-302. [27] Greitzer, F. L., & Hohimer, R. E. (2011). Modeling Human Behavior to Anticipate Insider Attacks. *Journal of Strategic Security*, 4(2), 25-48. [28] Nurse, J. R., Legg, P. A., Buckley, O., Agrafiotis, I., Wright, G., Whitty, M., & Creese, S. (2014). A Prescriptive Framework and Taxonomy for Insider Threat Monitoring and Detection. *Journal of Wireless Mobile 91 Networks, Ubiquitous Computing, and Dependable Applications*, 5(4), 71- 90. [29] Gamachchi, A., & Sun, L. (2018). A Graph-Based Framework for Malicious Insider Threat Detection. In *Proceedings of the IEEE 43rd Annual Computer Software and Applications Conference* (pp. 784-793). IEEE. [30] Shaw, E. D., & Sellers, L. (2015). Application of the Critical-Path Method to Evaluate Insider Risks. *Studies in Intelligence*, 59(2), 1-8.